Table of Contents

1. Introduction and Project Plan 5
1.1 Project Overview 5
1.2 Architecture Overview 5
1.3 Project Plan 6
2. Tools, Methodologies, Frameworks, and Benchmarking 7
2.1 Security Frameworks Applied 7
2.1.1 NIST Cybersecurity Framework 2.0 7
2.1.2 OWASP Top 10 7
2.1.3 CIS Benchmarks 7
2.2 Infrastructure Services and testing Tools 7
2.2.1 Security Testing Tools 7
2.2.2 AWS and Monitoring Services 7
2.3 WordPress Security Plugins 7
2.4 Default Security Posture and Rationale for Hardening 7
3.Technical Testing Approach 8
3.1 Methodology 8
3.2 Pre-Hardening Testing 8
3.3 Post-Hardening Testing 8
3.4 SSL\TLS Testing 9
3.5 Network Traffic Analysis – Wireshark 9
4. Findings and Risk Ratings 9
4.1 Pre-Hardening Findings Summary 9
4.2 Post-Hardening Findings Summary 10
4.3 Key Findings Analysis 10
4.3.1 Finding 1: Admin Username Enumeration (CVSS 7.5 - High) 10
4.3.2 Finding 2: XML-RPC Enabled (CVSS 7.2 - High) 10
4.3.3 Finding 3: SQL Injection on Comments Endpoint (CVSS 8.1 - High) 10
4.3.4 Finding 4: Missing Security Headers (Multiple CVSSs - High/Medium) 11
5. Challenges and limitations 11
5.1 AWS Academy IAM Restrictions 11
5.2 S3 Backup with UpdraftPlus Failed 11
5.3 RSS Feed Block 11
5.4 XML-RPC Block Caused Admin Lockout 12
5.5 CloudWatch Log Agent Credential Error 12
5.6 Residual Vulnerabilities – Accepted Risks 12
5.7 Future Production Improvements 12
6. Conclusion and Findings 13
6.1 Security Posture Summary 13
6.2 Lessons Learned 14
7. Critical Insights on UN Sustainability Goals 14
7.1 Goal 9 – Industry, Innovation and Infrastructure 14
7.2 Goal 12 – Responsible consumption and production 14

7.3 Goal 13 – climate Action 14
8. Individual and Team Member Contribution 15
References 15
Appendix 17
Appendix A: Infrastructure, Testing Tools and WordPress Security Tools 17
Infrastructure Services 17
Security testing Tools: 17
WordPress Security Plugins: 17
Appendix B: Complete Risk Register - Per and Post Hardening 18
Appendix C: EC2 and Infrastructure Configuration 19
C1 - EC2 Instance Running 19
C2 - Security Group Inbound Rules 20
C3 - Elastic IP Address 20
C4 - SSH configuration 20
C5 - Apache Security Headers 21
C6 - SSL Certificate Details 21
Appendix D: WordPress Configuration and Security 22
D1 - WordPress Dashboard 22
D2 - Wordfence Extended Protection 22
D3 - MFA Login Screen 23
D4 - Limit Login Attempts 23
D5 - WPS Hide Login 24
D6 - XML-RPC Blocked 24
D7 - wp-login.php Blocked 24
Appendix E: Pre-Hardening Scan Results 25
E1 - Nmap pre-hardening output 25
E2 - WPScan pre-hardening (exposed username) 26
E3 - Nikto pre-hardening (19 findings) 27
E4 - SSL Labs Grade A 27
E5 - Nessus pre-hardening (2 Medium findings) 28
E6 - OWASP ZAP pre-hardening alerts (23 findings) 29
Appendix F - Monitoring and Alerting Evidence 29
F1 - CloudWatch Dashboard 29
F2 - CloudWatch Alarms 30
F3 - SNS Topic and Subscription 30
F4 - SNS SMS Alert 30
F5 - Datadog Host Map 31
F6 - Datadog Metrics Dashboard 31
F7 - Datadog Apache Integration 32
F8 - CloudTrail Trail Active 32
Appendix G - Post-Hardening Scan Results 33
G1 - Nmap post (tcpwrapped, version hidden) 33
G2 - WPScan post (No Users Found) 33
G3 - Nikto post 34

G4 - SSL Labs Grade A+ 34
G6 - Nessus post (0 Medium/High/Critical) 35
G7 - OWASP ZAP post 36
G8 - Wireshark HTTP 301 redirect capture 36
G9 - Wireshark TLS encrypted HTTPS capture 37
Appendix H - Backup and Recovery Evidence 37
H1 - Backup Script and Files 37
H3 - EC2 Snapshots (5 stages) 37

1. Introduction and Project Plan

1.1 Project Overview

Cloud computing has radically changed the way organizations design and manage the infrastructure for IT. Platforms like Amazon Web Services enable businesses of large, medium and small to implement enterprise-grade systems on demand without having to make the substantial capital [1]. This convenience though comes with a considerable responsibility in security. The Cloud provider will secure the physical infrastructure, but the customer is completely responsible for securing the operating system and applications and data deployed on top, which is a principle known as the shared responsibility model. Misconfigurations, weak access controls and poor monitoring are the most leading causes of cloud security incidents, and the security misconfiguration is consistently listed by the OWASP Top 10 [2] as one of the most important web application risks. Understanding and addressing these risks is the focus of the this project.

The deployment target was the “cloud9security.tech”, a “.tech” domain was obtained through the GitHub Student Developer Pack, the domain was hosted on an AWS EC2 t3.micro instance that is running on Amazon Linux 2023. The site runs a LAMP stack Linux, Apache, MariaDB and PHP with WordPress 6.9.4 on top. What made this project particularly useful as a learning exercise was carrying out the testing on the system before and after hardening, which has helped us deepen our understanding of how security measures reduce the exposure and improve the overall resilience of a default deployment.

Security hardening was based on the three well-established frameworks: the NIST Cybersecurity Framework 2.0 [3], the OWASP Top [2] and the CIS Benchmarks for Amazon Web Services [4]. These references has helped to make practical decisions throughout the process, from how SSH was locked down, to how WordPress plugins were picked and configured.

1.2 Architecture Overview

The Final architecture include security controls at every tire, from the network perimeter to application. At the network level, AWS Security Groups has restricted inbound traffic to the HTTPS (port 443), HTTP redirect (port 80) and SSH (port 22, which is restricted to specific IP). By using the Certbot, a let’s Encrypt SSL certificate has been installed, which has provided the HTTPS with TLS 1.2 and 1.3, the older versions were explicitly disabled in Apache configuration [5], [6].

The EC2 instance runs the LAMP stack with the WordPress on top of the MariaDB. The database is available only through localhost, which means that it is never directly available from the internet, it is a deliberate architectural decision which eliminates an entire class of remote database attack. WordPress was hardened by using the Wordfence WAF, WP 2FA for the multi-factor authentication, Limit login attempts Reloaded for brute force protection and WPS Hide login to obscure the admin panel URL.

Monitoring is managed on the three platforms: AWS CloudWatch for the infrastructure metrics and triggering alarms [7], AWS CloudTrail for comprehensive API and console audit logging [8], Datadog for advanced monitoring and dashboards at the application level. Amazon SNS is used to send real-time mails alerts when alarms are triggered in the cloudWatch. Backups are managed by the combination of EC2 snapshots which are taken at four key project stages and a automated local backup script that runs daily.

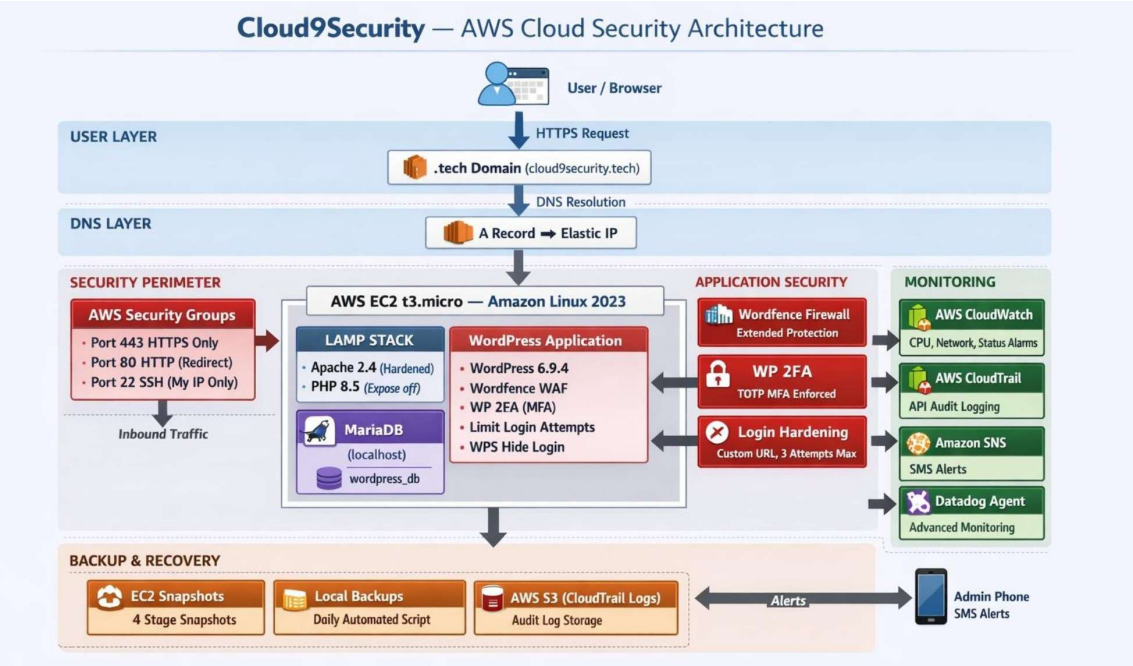


Figure 1: Cloud9Security AWS Architecture Diagram

1.3 Project Plan

The project was executed in a structured phases which covers infrastructure deployment, security hardening, monitoring and vulnerability testing:

Phase	Task	Description	Status
1	EC2 + LAMP	Launched EC2, configured security groups, installed LAMP stack Per AWS documentation [9]	Done
2	WordPress	Installed WordPress [10], connected domain, enabled HTTPS via Let's Encrypt [11]	Done
Pre	Pre-Hardening Scan	Baseline assessment across 6 tools – 32 vulnerabilities identified	Done
3	Infra Hardening	SSH, Apcahe, TLS config, security headers, file permissions	Done
4	WP Hardening	Wordfence [12], WP 2FA, Limit login, XML-RPC blocked, login URL changed	Done
5	Monitoring	CloudWatch [7], CloudTrail [8], SNS, Datadog, backups, snapshots	Done
Post	Post-Hardening	Same 6 tools re-run – 75% reduction in vulnerabilities confirmed	Done

2. Tools, Methodologies, Frameworks, and Benchmarking

2.1 Security Frameworks Applied

2.1.1 NIST Cybersecurity Framework 2.0

The NIST CSF 2.0 [3] is used as the overarching structure for the project. It has five core functions: Identify, Protect, Detect, Respond and Recover which are mapped cleanly on to the phases of the project. The identify phase points to the pre-hardening vulnerability scanning, Protect points to hardening phases 3 and 4, Detect points to CloudWatch and Datadog monitoring, Respond points to SNS alerting and incident notification, Recover points to EC2 snapshots and the backup strategy. By using the recognised framework like these, instead of simply applying security controls ad hoc, helped us to ensure the coverage was systematic rather than patchwork.

2.1.2 OWASP Top 10

The hardening decisions that are applied to the WordPress application are guided by the OWASP Top 10 [2]. Most of the pre-hardening findings are mapped directly to OWASP categories, the finding of the SQL injection on the comments endpoint maps to injection, the exposed admin credentials maps to Identification and Authentication Failures, and the absence of security headers maps to Security misconfiguration. Using the OWASP ZAP tool for the testing is a natural extension as the ZAP tool is a OWASP project which is specifically designed to test against these categories.

2.1.3 CIS Benchmarks

CIS Benchmarks for the AWS [4] has offered specific, prescriptive hardening advice for the EC2 layer. The key controls that has been implemented including disabling root SSH login, enforcing authentication using key-pairs only, hiding information about the server version, enabling automatic security updates and setting strict file permissions on the web directories. The CIS recommendations provided the confidence that infrastructure hardening was in accordance with the industry consensus rather than guesswork.

2.2 Infrastructure Services and testing Tools

2.2.1 Security Testing Tools

All the testing was performed from a kali Linux virtual machine, which has all the tools pre-installed for the testing and allowed testing to be performed from the perspective of the attacker without having to configure the installation of each tool on a separate system. **Detailed tool table is provided in Appendix A**

2.2.2 AWS and Monitoring Services

Check the Appendix A for detailed table

2.3 WordPress Security Plugins

The following WordPress security plugins were installed and configured to harden the application layer against common attack vectors:
Detailed table of security plugins are provided in Appendix A

2.4 Default Security Posture and Rationale for Hardening

One of the key observations that we have seen from the pre-hardening scan phase was just how exposed a default WordPress deployment is in its default configuration. The default LAMP stack has revealed the full version strings of the server, has directory listings, leaves XML-

RPC accessible and there are no security headers are set in the web server. The WordPress itself has exposed the admin username on the REST API, RSS feeds and the login error messages. This has shown us something important: that deploying to the cloud without post-installation hardening is not the neutral thing it is actively creating risk. The WordPress Security Whitepaper [13] states this directly, that the security of the WordPress platform is very dependent on how it is configured after the installation.

3.Technical Testing Approach

3.1 Methodology

The Security testing was conducted by using a black box approach, all the scans have been done from the kali Linux virtual machine and with knowledge of only the target domain name (cloud9security.tech), in order to simulate the external attacker. This is consistent with the way that the real-world penetration testing engagement is scoped when testing the public facing web applications. The kali Linux is not chosen randomly, it has pre-installed with all the necessary tools and is also popular in the professional field of security testing, which gives some credibility to the testing approach.

In this testing we have adopted a two-round testing approach, the round one is prior to any hardening was applied and the second identical round is done after all the hardening phases were completed. This is one of the most valuable methodological decisions of the project, because it has turned the results from a simple list of vulnerabilities into the measurable security improvement report. Having both the pre and post scanning data has made it possible to quantify exactly how much of the attack surface was reduced, which feeds indirectly into the risk register.

3.2 Pre-Hardening Testing

We have done the pre-hardening scans right after the installation of the WordPress and before any security measures were applied. So, from this we got the realistic picture of what the default deployment looked like to the attacker. The results were worse than expected, as there are 32 unique findings were found across the six tools, which covered everything from exposed admin credentials to the missing security headers to an accessible WordPress log file that could leak database connection details.

Key commands executed during pre-hardening assessment:

```
nmap -sV -sC -A cloud9security.tech -oN nmap_pre.txt
wpscan --url https://cloud9security.tech --enumerate u,vp,vt --api-token [TOKEN]
nikto -h https://cloud9security.tech -output nikto_pre.txt
```

Nessus Essentials has been run as the Basic Network Scan, after the scan it found 2 medium findings along with the 50 informational items. The OWASP has been used to perform the automated active scan for testing the OWASP Top 10 categories [2], it found 23 findings such as path traversal and several CSP issues. We have tested the domain over the SSL labs which gave the Grade A in the pre-hardening scan only positive baseline finding, which confirmed that the Let's Encrypt installation had been done correctly [14], [11].

3.3 Post-Hardening Testing

In post-hardening scans we have used the same commands and tools as the pre-hardening round so that the results are directly comparable. The improvement on all the tools was substantial. Nmap has showed the SSH service fingerprint has blocked (returning tcpwrapped rather than

OpenSSH version details), the Apache version is blocked, and Word Press version is removed from the HTTP headers. WPScan has returned no user found, which is a significant change from the pre-hardening scan where the admin username was exposed through 3 different detection methods.

We have found one unexpected finding during the post-hardening ZAP scanning was the presence of the SQL injection vulnerability on the WordPress comments endpoints (wp-comments-post.php). This one has not been appeared in the pre-hardening scan. The finding was then immediately remediated by blocking the endpoint via .htaccess and the follow up scan has been confirmed that this was remediated. This has reinforced the value of iterative testing; security is not a one-time activity.

3.4 SSL\TLS Testing

We have tested the domain by using the SSL labs to measure the SSL/TLS configuration both before and after the hardening. In pre-hardening scan, it gave Grade A, which has proved that the let's Encrypt certificate [18] was valid and the HTTPS functioned correctly. In post-hardening scan it gave the Grade A+ the highest possible rating: after the implementation of the HTTP strict transport security (HSTS) with max age of 31,536,000 seconds, subdomains included and the hover preload flag. The improvement of the Grade from A to A+ is because of the addition of HSTS header which is specifically checked by the SSL Labs as it prevents SSL stripping attack [15].

3.5 Network Traffic Analysis – Wireshark

The Wireshark is used to do the packet-level analysis of the traffic to make sure that the encryption part of the http was working as expected. Form the Capture 1 we have confirmed that the HTTP requests to port 80 resulted in an immediate 301 moved permanently redirect to HTTPS, unencrypted content is never served. The capture 2 has showed us that all the traffic over the HTTPS is encrypted by using TLS 1.3 which uses AES-256-GCM, which makes it completely unreadable of intercepted packets. Capture 3 is related to login attempt, which has confirmed that the login credentials submitted to the WordPress admin panel are transmitted only over encrypted HTTPS.

4. Findings and Risk Ratings

From the pre-hardening assessment scan, we have identified 32 weaknesses: 10 High, 15 Medium, 7 Low across 6 tools. After the post-hardening the scan has been confirmed an overall 75% reduction. All the high severity findings has been remediated or false positive. The Nessus has returned zero Medium/High/Critical. SSL Labs Grade has been improved from A to A+. The complete risk register is in the Appendix B.

4.1 Pre-Hardening Findings Summary

Severity	Count	Percentage	Primary Tools
High	10	31%	Nmap [16], WPScan [17], Nikto [18], ZAP [19]
Medium	15	47%	All 6 tools
Low	7	22%	Nikto, ZAP, Nessus
Total	32	100%	

The complete Pre- and Post-hardening risk results with the CVSS scores and remediation status for all the 32 findings is provided in Appendix B.

4.2 Post-Hardening Findings Summary

The following table compares pre and post-hardening results across all testing tools, demonstrating the measurable improvement in security posture:

Tool	Pre-Findings	Post-Findings	Reduction	Key Improvement
Nmap	5	1	80%	SSH hidden, versions hidden
WPScan	8	1	87%	No users found, XML-RPC gone
Nikto	19	6	68%	Headers, TRACE, Log files fixed
SSL Labs	Grade A	Grade A+	Improved	HSTS implementation confirmed
Nessus	2 Medium	0 Medium	100%	Both medium fully remediated
OWASP ZAP	23	12	48%	SQL injection, XSS Eliminated
Overall	32	8 Accepted	75%	Strong before vs after results

4.3 Key Findings Analysis

4.3.1 Finding 1: Admin Username Enumeration (CVSS 7.5 - High)

The WPScan has identified the administrator username which is “scap_admin” by using three different methods: RSS feed, REST API user endpoint, and login error messages. What we have noticed is that the passive detection alone was sufficient, no aggressive scanning is required. The remediation has been done by blocking the REST API user endpoint, and turning off RSS feeds, it is confirmed by the post-hardening WPScan which returned No User Found.

4.3.2 Finding 2: XML-RPC Enabled (CVSS 7.2 - High)

The WPScan has also identified that the XML-RPC endpoint was accessible, with the Rapid7 exploit module references which is cited in the output. This endpoint can be used to perform the DDOS amplification through the pingback and allows the brute force attack which bypasses the login limits. A .htaccess deny rule has been used to block all the access and it was confirmed by 403 forbidden response, which is aligning with the CIS Benchmark [4] recommendations for disabling the unused services.

4.3.3 Finding 3: SQL Injection on Comments Endpoint (CVSS 8.1 - High)

From the OWASP ZAP scan we have found the SQL injection to the wp-comments-post.php during the post hardening scanning, it was the highest CVSS scored finding and is direct injection match in the OWASP Top 10. Then we have disabled the WordPress comments immediately and the endpoint was blocked via .htaccess. From the follow-up scan we have confirmed the resolution.

4.3.4 Finding 4: Missing Security Headers (Multiple CVSSs - High/Medium)

Pre-hardening scans from the Nikto, ZAP, and Nessus has all confirmed that all the critical HTTP security headers were absent. Three tools confirming the same findings has significantly increased the confidence. So, we have added all the seven headers into the Apache security.conf and verified by curl. From the security header scanner SSL Lab has awarded Grade A and it has also upgrade to A+ after implementing the HSTS.

5. Challenges and limitations

In this section we have documented the real and practical challenges that we have faced during the implementation of project.

5.1 AWS Academy IAM Restrictions

The IAM (Identity and Access Management) controls the access of AWS services an EC2 instance can access. In the production environment an instance role would grant the permissions for writing logs to CloudWatch, and S3 for backups and SSM Session Manager. AWS Academy does not allow students to add IAM roles to EC2 instance at all.

This has blocked the three planned features. We have installed the CloudWatch Agent and configured it correctly, but it has given error as NoCredentialProviders errors on every start, without an instance role it cannot authenticate. The S3 CLI backup operations has gave AccessDeined errors with explicit deny policies on the bucket listing. SSM session Manger also was not available as an SSH alternative. For each problem we have done the alternative approach: Datadog for log monitoring, a local backup script for the file and database backups, and standard key-pair SSH everywhere. The CloudTrail is not impacted in any way because it runs account level. The Limitation is well known in the AWS well-architecture framework as a reason why the IAM roles are considered a foundational security control.

5.2 S3 Backup with UpdraftPlus Failed

The UpdraftPlus is the WordPress backup plugin with direct S3 support. The main idea here is to use it to set daily backups to the dedicated S3 bucket.

The AWS academy uses temporary credentials that expire with the end of each lab session, new access keys, secret keys and session tokens are generated with each session. The UpdraftPlus doesn't support the session tokens, so the plugin has reported the InvalidAccessKeyId errors even with the newly entered credentials. We have tried to use the AWS CLI directly which was also failed, the CLI returned AccessDenied errors on all the S3 bucket operations due to explicit IAM deny policies. The final solution that we have decided was the local backup script based on the tar and mysqldump with the backups stored in timestamped files on the EC2 instance with the daily cron job.

5.3 RSS Feed Block

From the WPScan we have identified the admin username through RSS passive detection. The Disable Feeds plugin was installed to fix this but the followup WPScan has still showed the username, the plugin that has installed has not blocked the feed URL effectively.

So, we have applied a fix directly in .htaccess using RewriteRule directives to return 403 Forbidden for all the feed URL patterns. A third run of the WPScan has confirmed the fix, the scan returned No Users Found. This is one of the more satisfying fixes in the project given how prominently the username had figured in the earlier scans.

5.4 XML-RPC Block Caused Admin Lockout

While doing the phase 4 hardening a .htaccess block has been added for denying the access to xmlrpc.php. At the same time, a second block was also added that denies access to wp-login.php with the intention of preventing the direct access to the URL after WPS Hide Login has changed it.

What is not considered was that WPS Hide Login internally still routes through wp-login.php logic, so blocking that file has completely prevents the WordPress from processing any login request, including via the custom URL. The result was the 403 Forbidden error on every attempt to log in as an administrator. The access to it was regained by SSHing into the EC2 instance directly and deleting the wp-login.php deny line in .htaccess. From this we have learned that the WPS Hide login takes care of its own URL access control – adding a server level block on top of it will breaks the plugin's own redirect mechanism.

5.5 CloudWatch Log Agent Credential Error

We have installed the CloudWatch agent and configured it to collect the Apache access logs, error logs and SSH authentication logs. When started, the agent seemed to have a running, but the log file showed repeated NoCredentialProviders errors.

The root cause of this was the IAM restriction which is described in the section 5.1. Without the instance role the agent has no way to obtain AWS credentials and cannot authenticate with the CloudWatch logs. So, the agent has been stopped and disabled to avoid the resource consumption due to the repeated failed tries. The configuration file was kept to demonstrate the intended architecture. The Datadog agent has been used as the compensating control for log monitoring throughout the entire project.

5.6 Residual Vulnerabilities – Accepted Risks

Not all findings were fully remediable. The following table list is approved list and the reasoning behind each decision:

Vulnerability	CVSS	Reason Accepted
CSP unsafe-inline and unsafe-eval	6.1	Required for WordPress core JS and theme functionality - removing breaks site rendering
WordPress version via CSS query params	5.3	Core WordPress appends version to CSS files - modifying core files is not recommended practice
Path traversal on oEmbed endpoint	5.0	Low confidence ZAP finding (Confidence: Low) on standard WordPress oEmbed API - assessed as false positive
Timestamp disclosure	2.6	Minor information disclosure, low exploitability, no practical attack path identified
EC2 hostname visible in DNS	2.1	Inherent AWS infrastructure characteristic - cannot be mitigated at the instance level

5.7 Future Production Improvements

Looking beyond the limitations of the academic environment, there are several other security controls that we would have applied in a production deployment:

- AWS WAF at CloudFront level used for the advanced rule-based filtering and DDOS mitigation, which is aligned with the AWS well-Architecture Security pillar guidance [1].

- Full IAM roles with least privilege attached to the EC2 instance, which enables the CloudWatch Logs, S3 backups and SSM session Manager as an SSH alternative.
- AWS GuradDuty for intelligent threat detection using machine learning.
- An Automated security scanning integrated into a CI/CD pipeline to catch regressions on deployment.

6. Conclusion and Findings

This project main idea is to deploy and comprehensively secure the WordPress web application on the AWS, and the results of which are measurable strong. We have started with a default installation with 32 vulnerabilities, including an exposed admin username found using only passive scanning alone, an accessible XML-RPC endpoint and no security headers. After doing a systematic hardening it reduced findings by 75%. All the 10 high severity findings were fully remediated or identified as the false positive, and the Nessus has returned zero medium, high or critical vulnerabilities post-hardening. SSL Labs has went from A to A+ as a result of the HSTS implementation.

The unexpected SQL injection finding during the post-hardening ZAP scanning was the good remainder of how the security is not one-time exercise, even after a hardening phase the continued testing is important. The services such as CloudWatch, CloudTrail, SNS and Datadog has together provided a monitoring layer that has given a real visibility into the infrastructure behaviour. We have tested the SNS SMS alert system, where the email notification has been sent within seconds of the CPU alarm being simulated, confirmed the alerting chain works in practice.

The AWS Academy IAM restriction is the most persistent challenge throughout. It has blocked the CloudWatch log integration and S3 CLI backup operations. These limitations are instructive, they have reflected the fact that the cloud deployments rarely goes exactly to the plan, and the ability of identifying the workarounds for those issues and documenting the limitations honestly is a part of good security engineering.

6.1 Security Posture Summary

Metric	Pre-Hardening	Post-Hardening
Total vulnerabilities	32	8 (accepted risks only)
High severity findings	10	1 (false positive-low confidence)
Medium severity findings	15	6 (WordPress core requirements)
Nessus critical/high/medium	2 Medium, 0 High/Critical	0 Medium, 0 High, 0 Critical
SSL Labs grade	A	A+
Security headers grade	None present	Grade A+ (all 7 headers)
MFA implemented	No	Yes - TOTP enforced for admin

Monitoring active	No	Yes - CloudWatch, CloudTrail, Datadog
Automated backups	No	Yes - daily script + 4 snapshots
Overall remediation rate	Baseline – 32 findings	75% reduction in findings

6.2 Lessons Learned

- A default deployments are not secure. The fresh installation of the WordPress has 32 vulnerabilities before any security hardening was done. Demonstrating that deploying without the post-hardening security process is actively creating risk.
- It is important to do the testing before and after hardening, not only after. This before and after comparison was the most valuable output of the project, as it was used to quantify what was fixed and also it brought up the SQL injection finding which did not appear in the pre-hardening scans.
- The Cloud restrictions has shaped our architecture. Because of these IAM restrictions we are forced to alternative approaches that are more creative than the original plan. Understanding how to work with in the platform constraints is a practical skill.
- Collecting the evidence is as important as the technical work. Taking the screenshots at every stage of the project and saving the scan outputs has made the report writing simple. In the professional engagement, the evidence trail is the deliverable.

7. Critical Insights on UN Sustainability Goals

7.1 Goal 9 – Industry, Innovation and Infrastructure

This project is an example of how the cloud computing has lowered the barrier to implement secure, professional grade infrastructure. On AWS, a hardened WordPress environment has been implemented including monitoring, MFA, automated backups and vulnerability scanning, which is achievable within the student credit allocation, this infrastructure that would have cost considerable hardware investment with an on-premises model. The t3.micro instance type is also shows an example of right-sizing: it actually matches the resource consumption to the actual workload instead of overprovisioning.

7.2 Goal 12 – Responsible consumption and production

The Cloud computing's pay-per-use model lends itself perfectly to the responsible consumption – EC2 instances were stopped when not in use during the duration of this project, which has eliminated the unnecessary use of energy during the times of inactivity. The economics of scale in cooling and power management has benefits the AWS data centres which cannot be achieved by the individual deployments, resulting in cloud hosting being, by definition, more resource-efficient than the equivalent infrastructure hosted on-premise.

7.3 Goal 13 – climate Action

The AWS has made the public commitments towards the renewable energy for its global infrastructure [6]. By hosting on the AWS instead of dedicated physical hardware means that the carbon footprint is reduced through the consolidation and renewable sourcing. The cloud native services like CloudTrail and CloudWatch has also decreased the requirement for the dedicated security monitoring appliances, which additionally reduced the physical footprint compared to an equivalent op-premise deployment.

8. Individual and Team Member Contribution

The following table outlines each team member's contribution to the project:

Team Member	Student ID	Key Contributions	Weight
Satya Vardhan	24273384	EC2 setup, LAMP installation, Phase 3 infrastructure hardening, Nmap and Nessus scanning	33%
Srikar	24200221	WordPress installation and configuration, Phase 4 WordPress hardening, WPScan and ZAP testing	33%
Keerthana	23326981	Phase 5 monitoring setup, Nikto and Wireshark testing, report writing, presentation preparation	34%

References

[1] Amazon Web Services (AWS), "Security Pillar - AWS Well-Architected Framework - Security Pillar," AWS Documentation. Accessed: Mar. 17, 2026. [Online]. Available: https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html

[2] OWASP Foundation, "OWASP Top 10:2025," OWASP. Accessed: Mar. 17, 2026. [Online]. Available: https://owasp.org/Top10/2025/

[3] National Institute of Standards and Technology, "The NIST Cybersecurity Framework (CSF) 2.0," National Institute of Standards and Technology, Gaithersburg, MD, NIST CSWP 29, Feb. 2024. doi: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf.

[4] Center for Internet Security (CIS), "CIS Amazon Web Services Benchmarks," CIS. Accessed: Mar. 17, 2026. [Online]. Available: https://www.cisecurity.org/benchmark/amazon_web_services

[5] Nick Sullivan, "A Detailed Look at RFC 8446 (a.k.a. TLS 1.3)," The Cloudflare Blog. Accessed: Mar. 17, 2026. [Online]. Available: https://blog.cloudflare.com/rfc-8446-aka-tls-1-3/

[6] OWASP Cheat Sheet Series Team, "Transport Layer Security - OWASP Cheat Sheet Series," OWASP Cheat Sheet Series. Accessed: Mar. 17, 2026. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html

[7] Amazon Web Services (AWS), "What is Amazon CloudWatch? - Amazon CloudWatch," AWS Documentation. Accessed: Mar. 17, 2026. [Online]. Available: https://docs.aws.amazon.com/AmazonCloudWatch/latest/monitoring/WhatIsCloudWatch.html

[8] Amazon Web Services (AWS), "AWS CloudTrail User Guide," AWS Documentation. Accessed: Mar. 17, 2026. [Online]. Available: https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-user-guide.html

[9] Amazon Web Services (AWS), "Tutorial: Install a LAMP server on AL2023 - Amazon Linux 2023," AWS Documentation (Amazon Linux 2023 User Guide). Accessed: Mar. 17, 2026. [Online]. Available: https://docs.aws.amazon.com/linux/al2023/ug/ec2-lamp-amazon-linux-2023.html

[10] Amazon Web Services (AWS), "Tutorial: Host a WordPress blog on AL2023 - Amazon Linux 2023," AWS Documentation (Amazon Linux 2023 User Guide). Accessed: Mar. 17, 2026. [Online]. Available: https://docs.aws.amazon.com/linux/al2023/ug/hosting-wordpress-aml-2023.html

[11] Internet Security Research Group (ISRG), "Let's Encrypt Documentation," Let's Encrypt. Accessed: Mar. 19, 2026. [Online]. Available: https://letsencrypt.org/docs/

[12] Wordfence, "Wordfence Help," Wordfence. Accessed: Mar. 29, 2026. [Online]. Available: https://www.wordfence.com/help/

[13] WordPress Security Team, "Security," WordPress.org. Accessed: Mar. 19, 2026. [Online]. Available: https://wordpress.org/about/security/

[14] Qualys SSL Labs, "SSL Server Test (Powered by Qualys SSL Labs)," SSL Labs. Accessed: Mar. 29, 2026. [Online]. Available: https://www.ssllabs.com/ssltest/

[15] Mozilla Contributors, "Strict-Transport-Security header - HTTP | MDN," MDN Web Docs. Accessed: Mar. 20, 2026. [Online]. Available: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security

[16] Gordon Lyon, “Nmap Network Scanning—The Official Nmap Project Guide to Network Discovery and Security Scanning,” Nmap.org. Accessed: Mar. 29, 2026. [Online]. Available: https://nmap.org/book/
[17] WPScan Team, *wpscanteam/wpscan*. (Mar. 29, 2026). Ruby. WPScan - WordPress Security. Accessed: Mar. 20, 2026. [Online]. Available: https://github.com/wpscanteam/wpscan
[18] CIRT.net / Chris Sullo, “Nikto,” cirt.net. Accessed: Mar. 21, 2026. [Online]. Available: https://cirt.net/nikto/
[19] ZAP by Checkmarx / OWASP Community, “ZAP (Zed Attack Proxy),” ZAP Official Website. Accessed: Mar. 21, 2026. [Online]. Available: https://www.zaproxy.org/

Appendix

Appendix A: Infrastructure, Testing Tools and WordPress Security Tools

Infrastructure Services

Service	Provider	Purpose	Rationale
EC2 t3.micro	AWS	Host server — Amazon Linux 2023	AWS Academy access, cost-effective
CloudTrail	AWS	API and console audit logging [10]	Compliance and incident investigation
Amazon SNS	AWS	SMS/email alert notifications	Real-time alarm delivery
Datadog	Datadog Inc.	Advanced monitoring, dashboards, anomaly detection	Industry-leading anomaly detection
Let's Encrypt	ISRG	Free SSL certificate via Certbot [18]	Free, automated, trusted CA
CloudWatch	AWS	Infrastructure monitoring and alarms [9]	Native AWS, integrates with SNS

Security testing Tools:

Tool	Version	Layer Tested	Purpose
Nmap	7.95	Infrastructure	Port scanning, service detection, OS fingerprinting [14]
WPScan	3.8.28	WordPress App	WordPress vulnerability scanning, user enumeration, CVE detection [22]
Nikto	2.5.0	Web Server	Server misconfiguration, dangerous files, security headers [21]
Nessus Essentials	Latest	Full Stack	Professional vulnerability assessment with CVSS scoring [16]
OWASP ZAP	2.17.0	Web Application	OWASP Top 10 active and passive scanning [15]
SSL Labs	Online	SSL/TLS	Certificate validation, TLS version, cipher grading [17]
Wireshark	Latest	Network Traffic	Packet capture, encryption verification [19]

WordPress Security Plugins:

Plugin	Purpose	Configuration applied
Wordfence [12]	WAF + malware scanner	Extended Protection mode, brute force protection enabled
WP 2FA	Multi-Factor authentication	TOTP enforced for all admin accounts via Google Authenticator
Limit Login Attempts Reloaded	Brute force protection	3 attempts max, 20-minute lockout, email alert on lockout
WPS Hide Login	Login URL obfuscation	Default /wp-login.php changed to custom URL
Disable feeds	RSS feed security	Prevents username and version enumeration via RSS feed

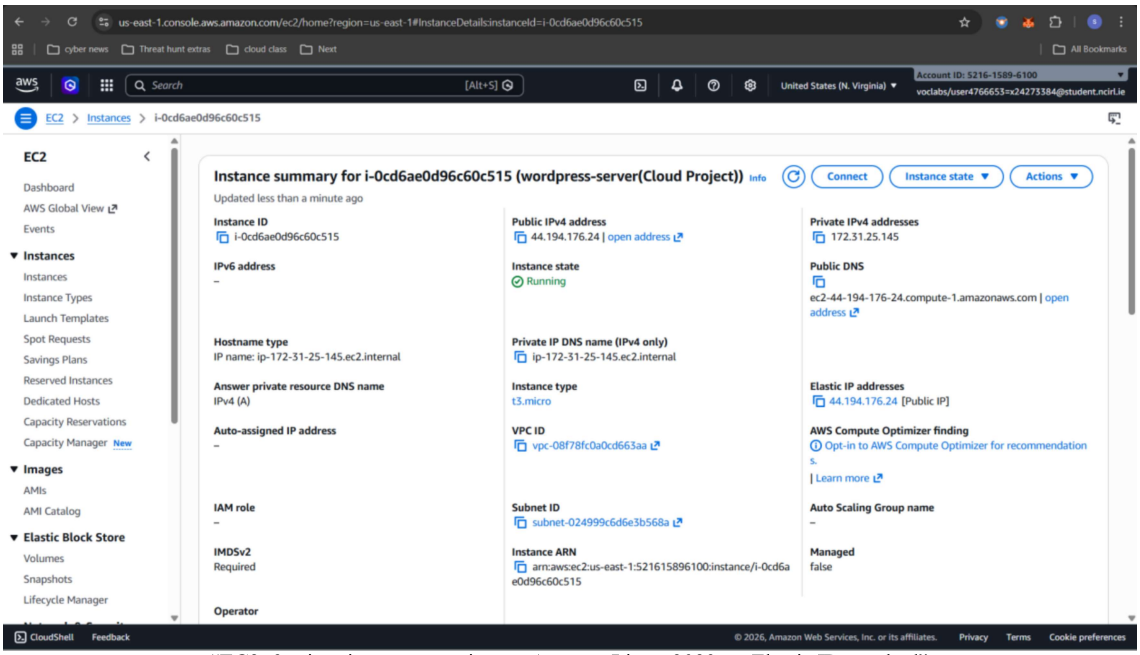
Appendix B: Complete Risk Register - Per and Post Hardening

	Vulnerability	Tool	Risk	CVSS	Post-Hardening Status
1	SSH port 22 open to internet	Nmap	High	7.5	Fixed (restricted to My IP in Security Group)
2	Admin username exposed (scap_admin)	WPScan	High	7.5	Fixed (REST API blocked, RSS feeds disabled)
3	SQL Injection on comments endpoint	ZAP	High	8.1	Fixed (comments disabled, endpoint blocked)
4	wp-app.log publicly accessible	Nikto	High	7.2	Fixed (file deleted, .htaccess block added)
5	XML-RPC endpoint enabled	WPScan	High	7.2	Fixed (blocked via .htaccess, 403 confirmed)
6	X-Frame-Options header missing	Nikto, ZAP	High	6.5	Fixed (header added in Apache security.conf)
7	HSTS header not configured	Nessus, Nikto, ZAP	High	6.5	Fixed (HSTS added, SSL Labs upgraded to A+)
8	HTTP TRACE method enabled	Nessus, Nikto	High	6.5	Fixed (TraceEnable off in Apache config)
9	Directory indexing on /icons/	Nikto, ZAP	High	6.5	Fixed (Options -Indexes in autoindex.conf)
10	Upload directory publicly browsable	WPScan, Nikto	High	6.5	Fixed (.htaccess deny rule on uploads folder)
11	Potential XSS — 8 instances	ZAP	Medium	6.1	Fixed (Wordfence WAF [12] blocks XSS attempts)
12	Content Security Policy missing	ZAP	Medium	6.1	Fixed (CSP header added in Apache config)
13	Cookie No HttpOnly flag	ZAP	Medium	5.4	Fixed (resolved by disabling comments)
14	Cookie without SameSite attribute	ZAP	Medium	5.4	Fixed (resolved by disabling comments)
15	Cookie poisoning	ZAP	Medium	5.4	Fixed (resolved by disabling comments)
16	No Anti-CSRF tokens	ZAP	Medium	5.3	Accepted (Wordfence [12] provides CSRF protection)
17	Apache version disclosed	Nmap, Nessus, ZAP	Medium	5.3	Fixed (ServerTokens Prod in httpd.conf)
18	PHP version exposed (X-Powered-By)	Nikto, ZAP	Medium	5.3	Fixed (expose_php=Off in php.ini)
19	X-Content-Type-Options missing	Nikto, ZAP	Medium	5.3	Fixed (header added in Apache security.conf)
20	readme.html exposed	WPScan	Medium	5.3	Fixed (file deleted from server)
21	Apache default files found	Nikto	Medium	5.3	Fixed (icons directory denied)

22	WordPress version exposed	WPScan, Nikto	Medium	5.3	Partial (CSS query params remain, accepted risk)
23	WP-Cron publicly accessible	WPScan	Medium	4.8	Fixed (DISABLE_WP_CRON set in wp-config.php)
24	wp-login.php default URL exposed	Nikto	Medium	4.8	Fixed (URL changed via WPS Hide Login)
25	wp-admin listed in robots.txt	WPScan	Medium	4.3	Fixed (robots.txt updated, wp-admin removed)
26	REST API user enumeration	Nikto	Low	3.1	Fixed (REST API user endpoint blocked)
27	Timestamp disclosure	ZAP	Low	2.6	Accepted (minor info disclosure, low risk)
28	Suspicious HTML comments	ZAP	Low	2.1	Accepted (WordPress core generated)
29	Cache-control misconfigured	ZAP	Low	2.1	Accepted (WordPress default, low impact)
30	Theme files location exposed	WPScan	Low	2.1	Fixed (readme.txt blocked via .htaccess)
31	OS fingerprint detected	Nessus	Low	2.1	Accepted (inherent to AWS EC2 infrastructure)
32	license.txt exposed	Nikto	Low	2.1	Fixed (file deleted from server)

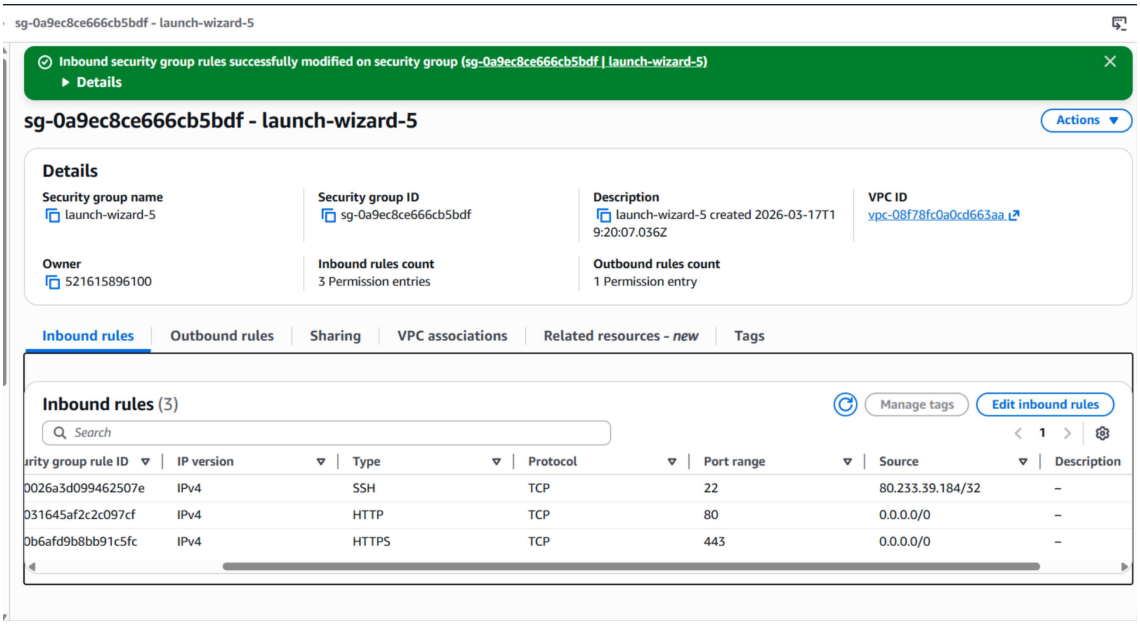
Appendix C: EC2 and Infrastructure Configuration

C1 - EC2 Instance Running



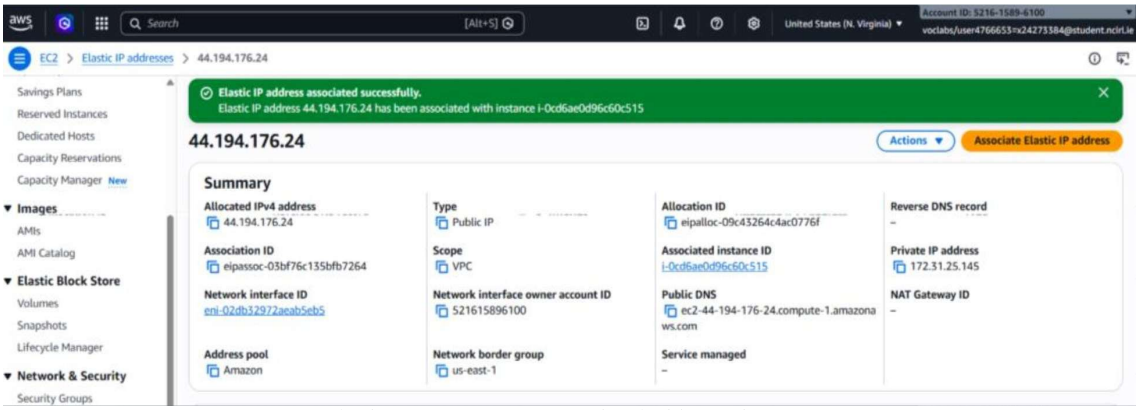
"EC2 t3.micro instance running on Amazon Linux 2023 — Elastic IP attached"

C2 - Security Group Inbound Rules



"Security Group inbound rules — only ports 22, 80 and 443 permitted"

C3 - Elastic IP Address



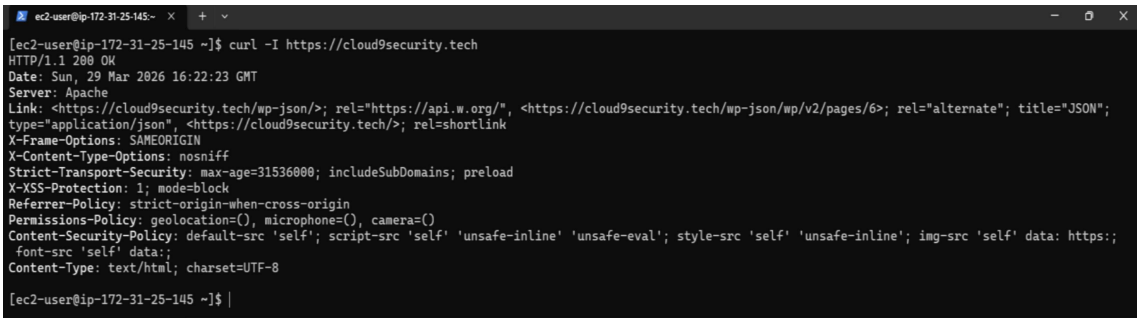
"Elastic IP 44.194.176.24 associated with EC2 instance"

C4 - SSH configuration



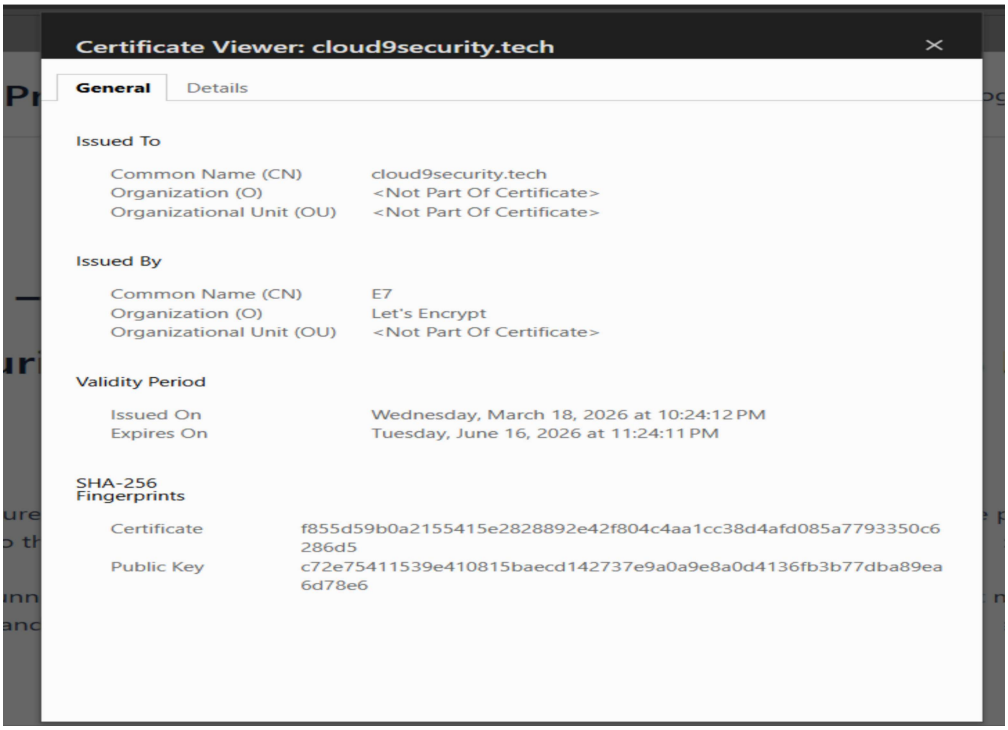
"SSH hardening confirmed - root password login disabled (without-password), password authentication disabled and empty passwords blocked. Key-pair authentication is the only permitted access method."

C5 - Apache Security Headers



"All 7 HTTP security headers confirmed via curl output"

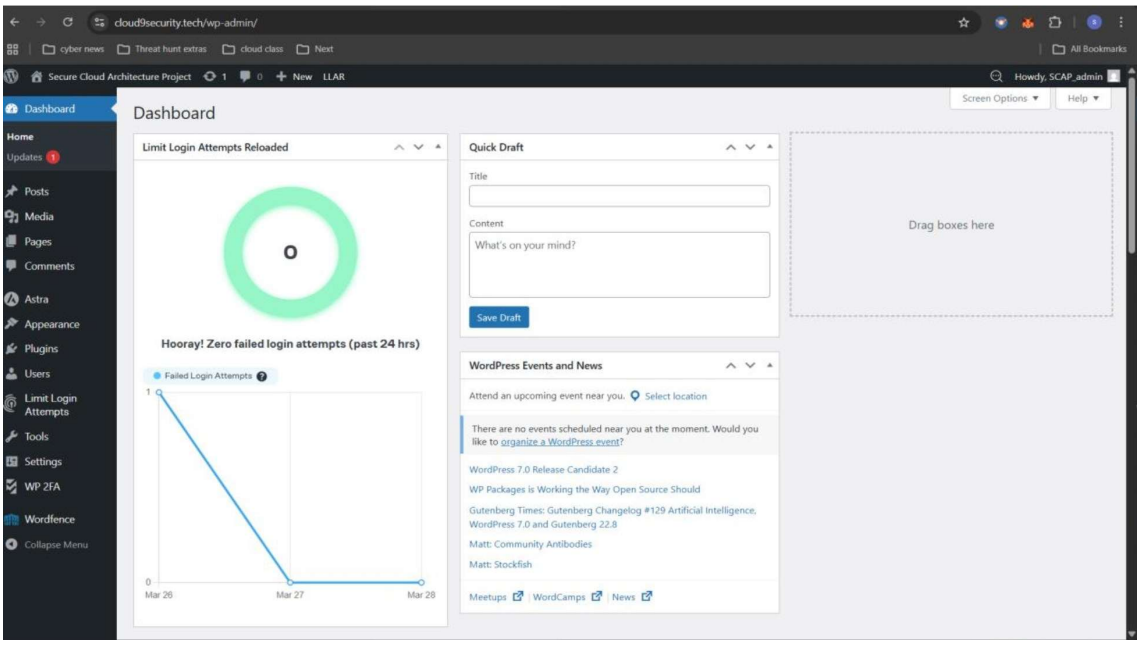
C6 - SSL Certificate Details



"Let's Encrypt SSL certificate — valid and covering cloud9security.tech"

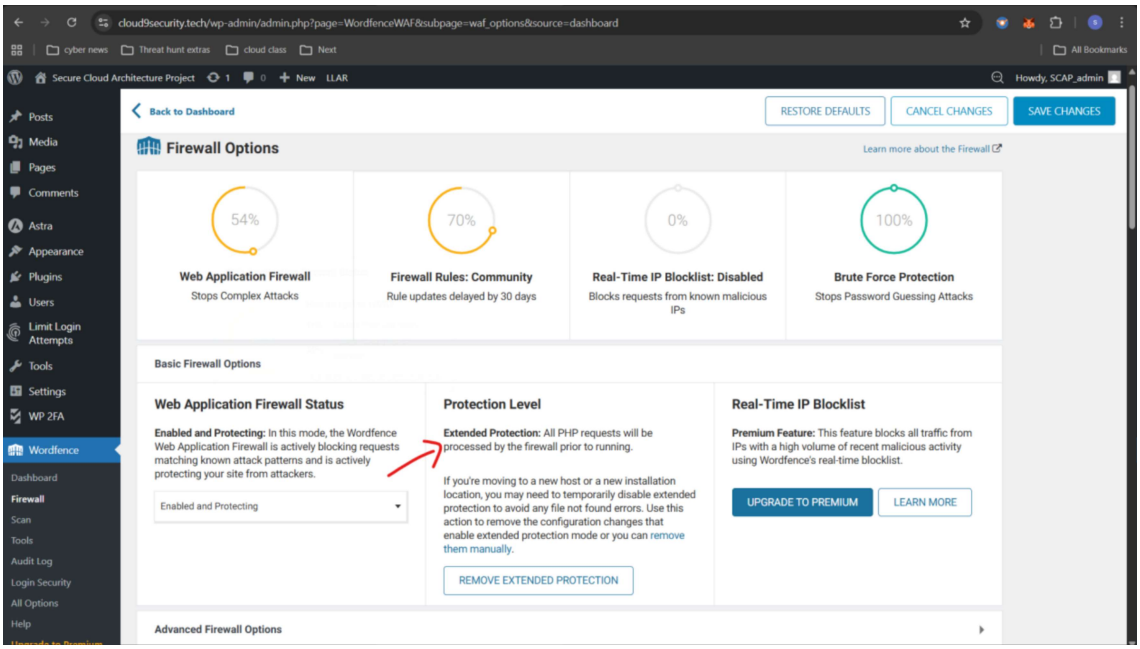
Appendix D: WordPress Configuration and Security

D1 - WordPress Dashboard



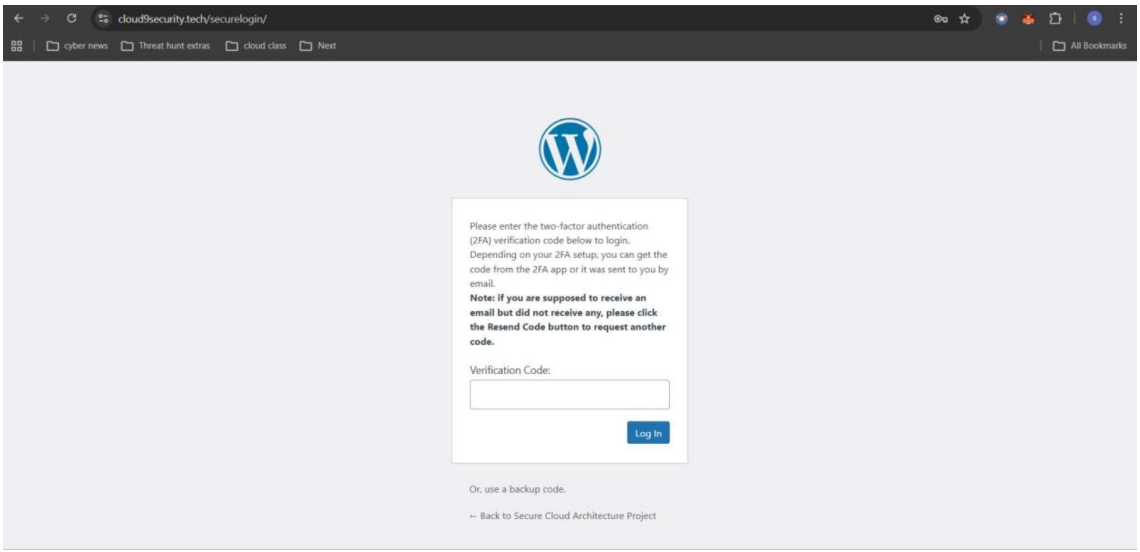
"WordPress 6.9.4 dashboard — latest version with no known CVEs."

D2 - Wordfence Extended Protection



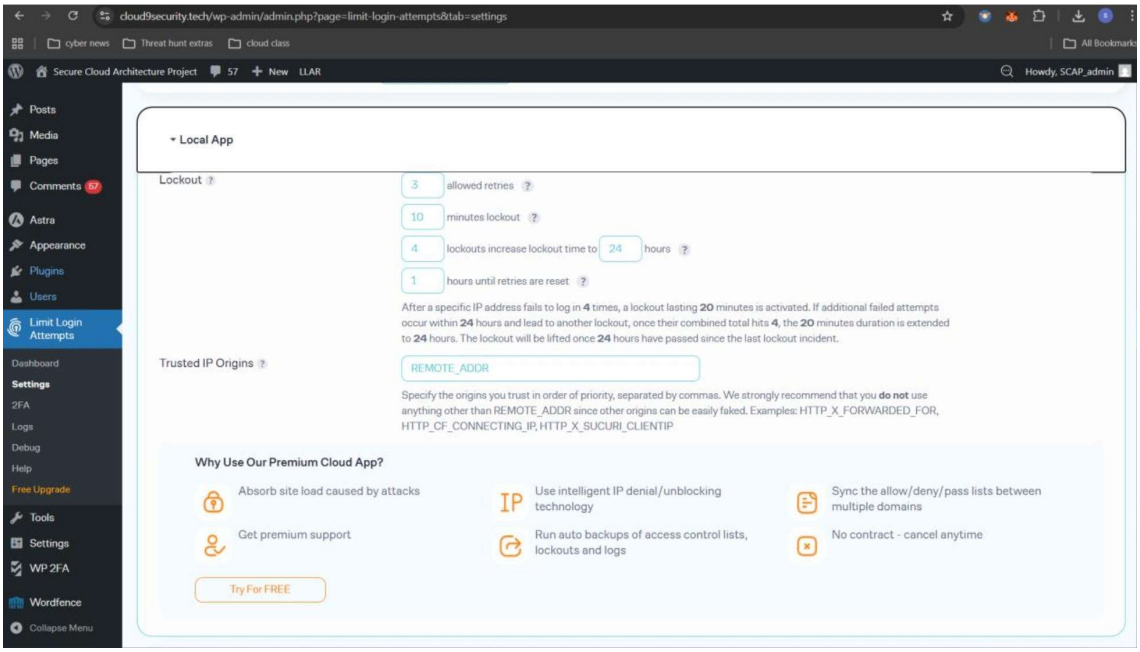
"Wordfence firewall active in Extended Protection mode — blocks malicious traffic before it reaches WordPress."

D3 - MFA Login Screen



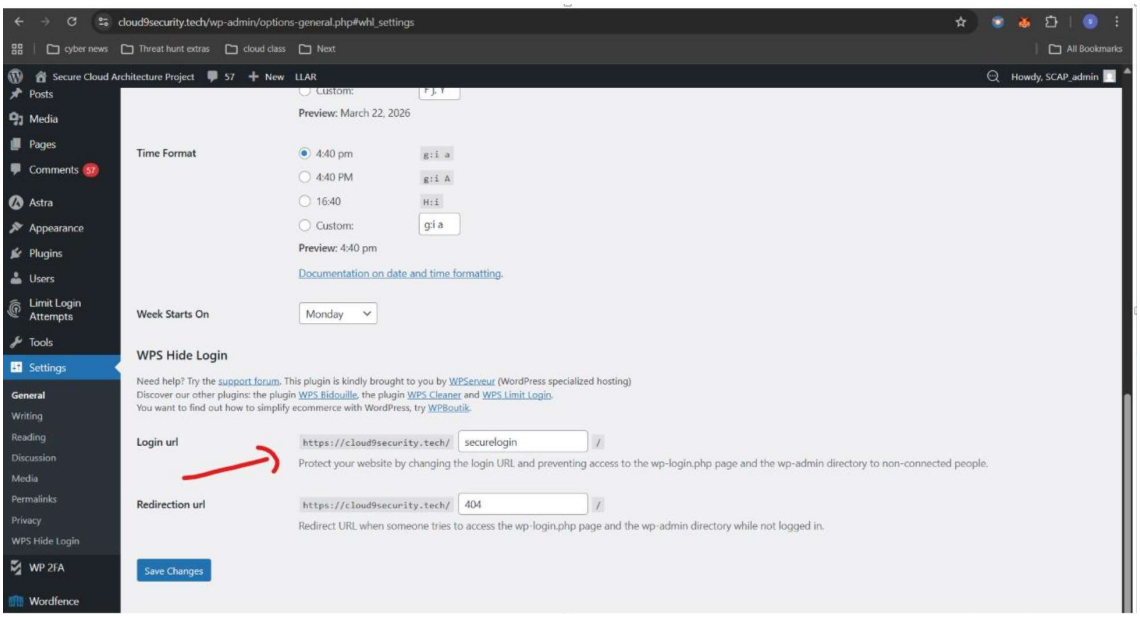
"WP 2FA enforcing TOTP multi-factor authentication — OTP required for all admin logins."

D4 - Limit Login Attempts



"Brute force protection configured — 3 attempts maximum, 10-minute lockout, email alert on lockout."

D5 - WPS Hide Login



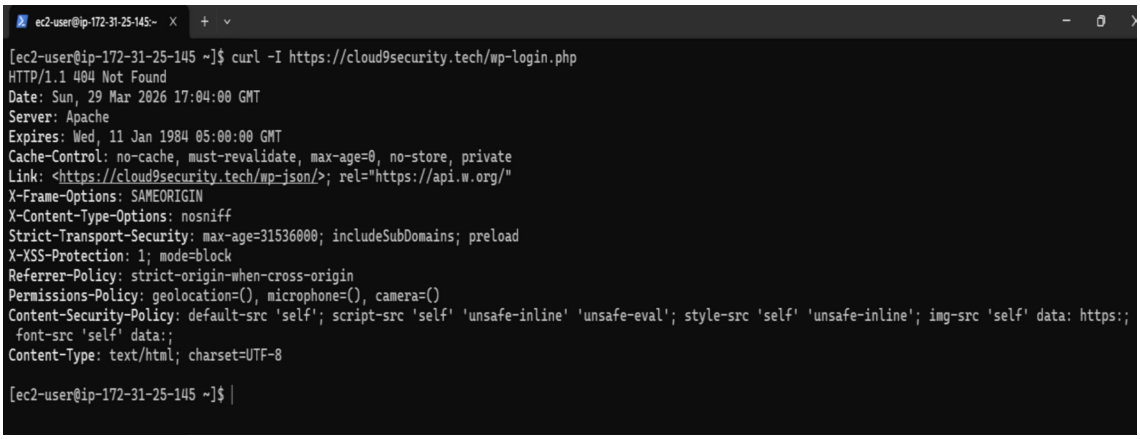
"Default /wp-login.php replaced with custom login URL — obscures admin panel from automated scanners."

D6 - XML-RPC Blocked



"XML-RPC endpoint returning 403 Forbidden - DDoS amplification and brute force attack vector eliminated."

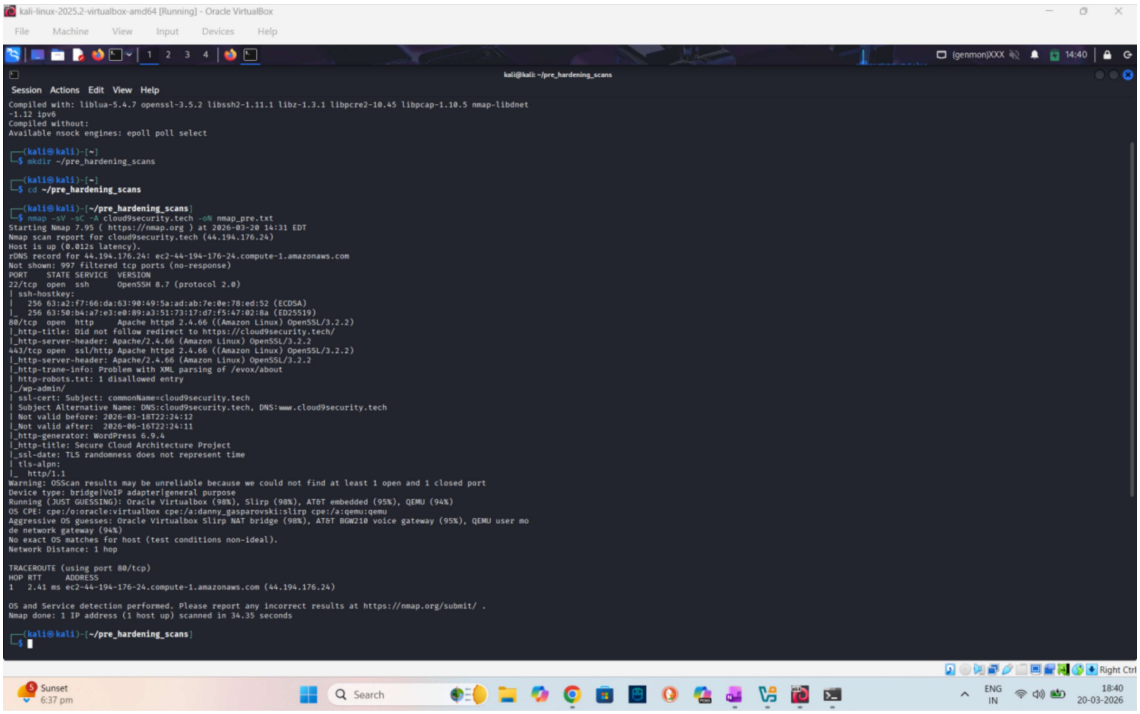
D7 - wp-login.php Blocked



"Default login URL returning 404 Not Found - WPS Hide Login removes the default login page, making it appear non-existent to attackers."

Appendix E: Pre-Hardening Scan Results

E1 - Nmap pre-hardening output

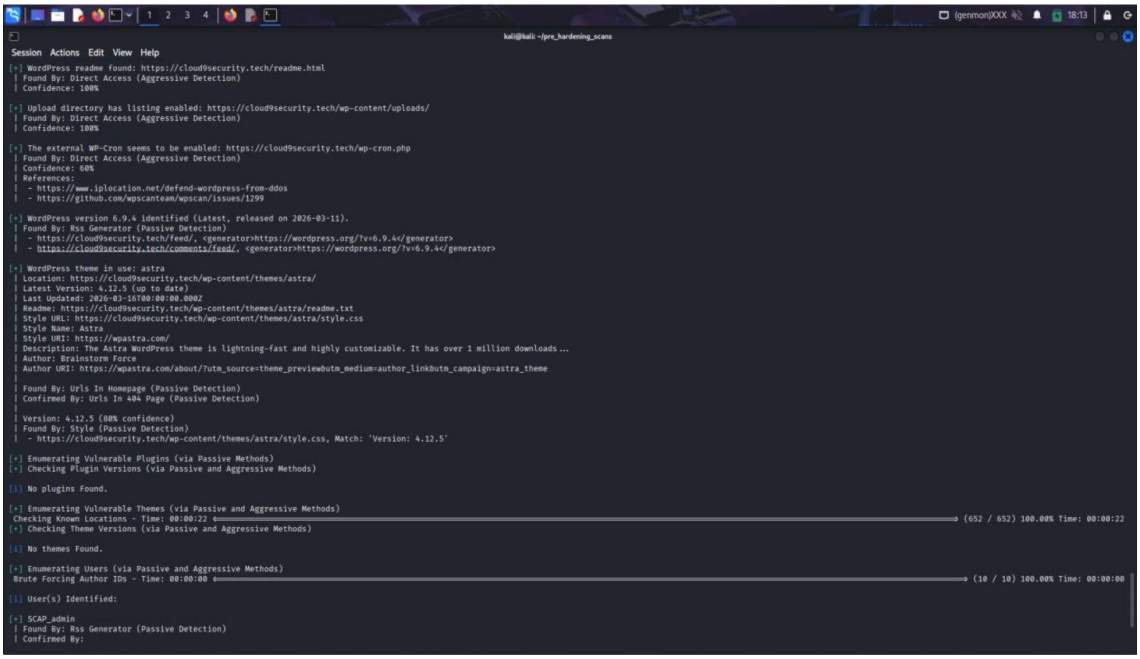


"Nmap scan revealing open ports and exposed service versions — Apache 2.4.66, OpenSSH 8.7 and WordPress 6.9.4 version visible in headers."

E2 - WPScan pre-hardening (exposed username)

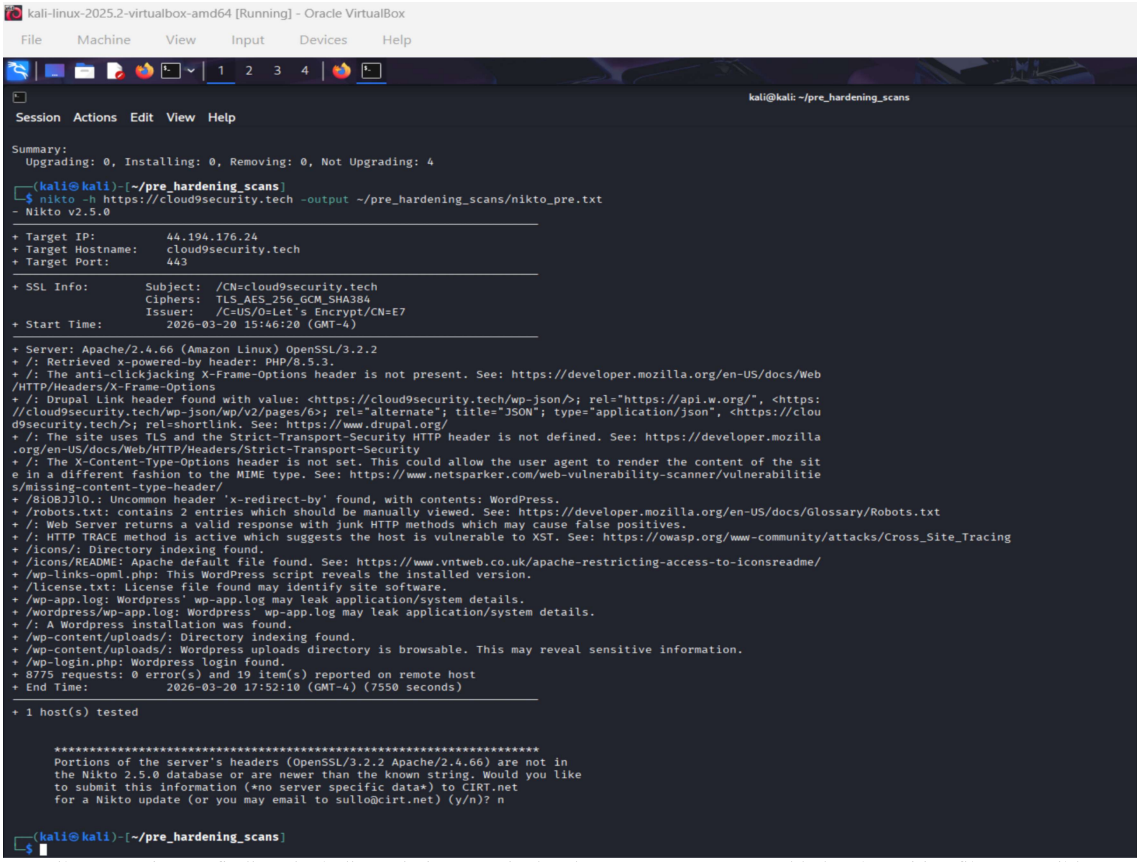
"WPScan identifying admin username SCAP_admin through passive RSS feed detection — confirmed by REST API and login error messages."







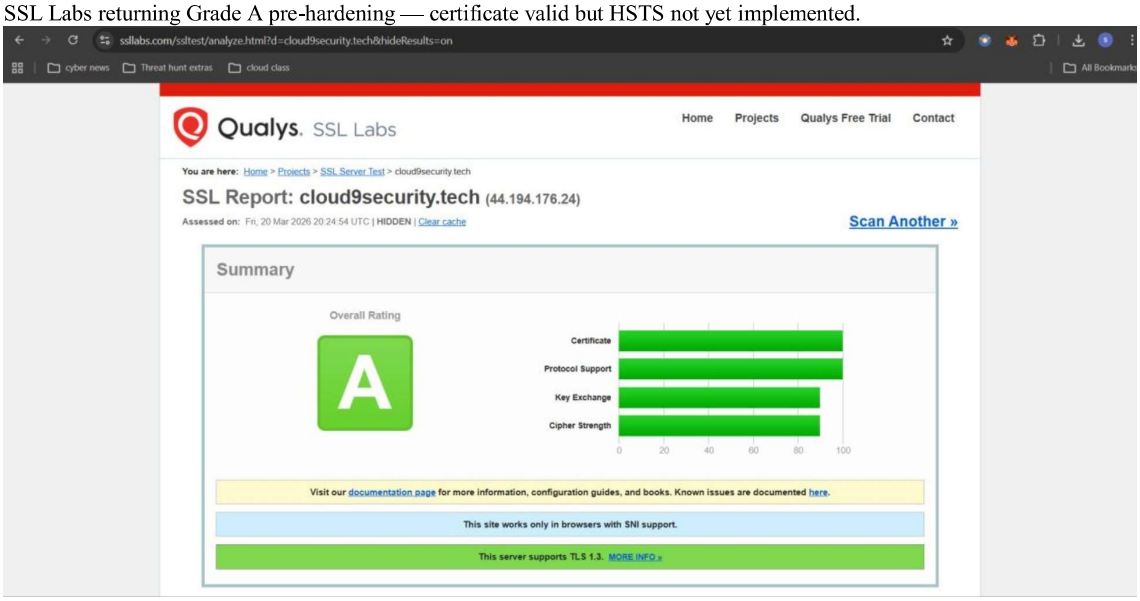
E3 - Nikto pre-hardening (19 findings)

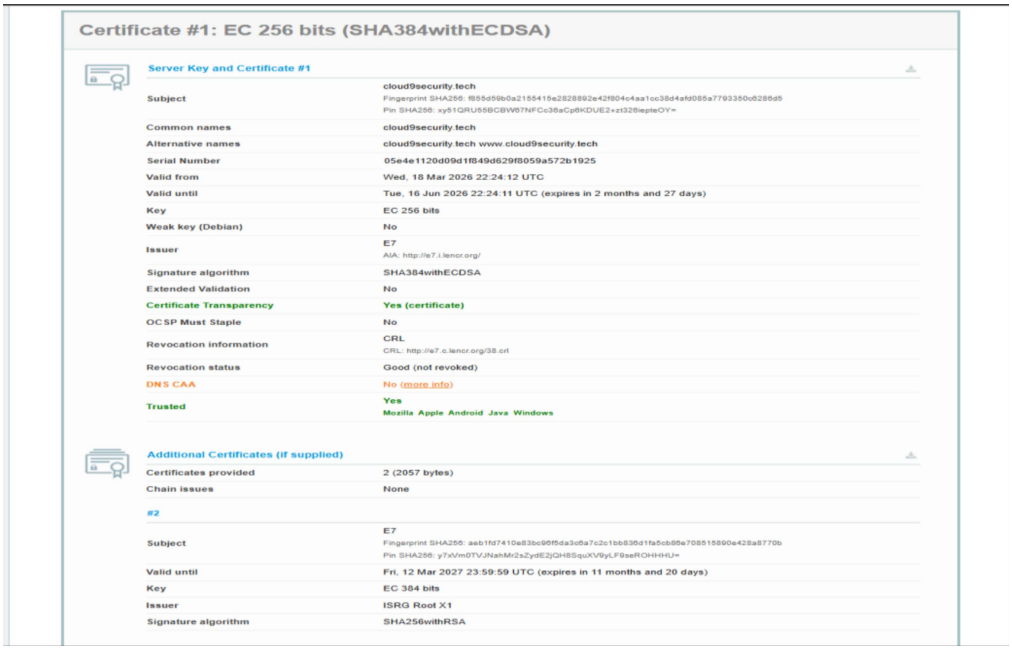


"Nikto returning 19 findings including missing security headers, HTTP TRACE enabled and sensitive files accessible."

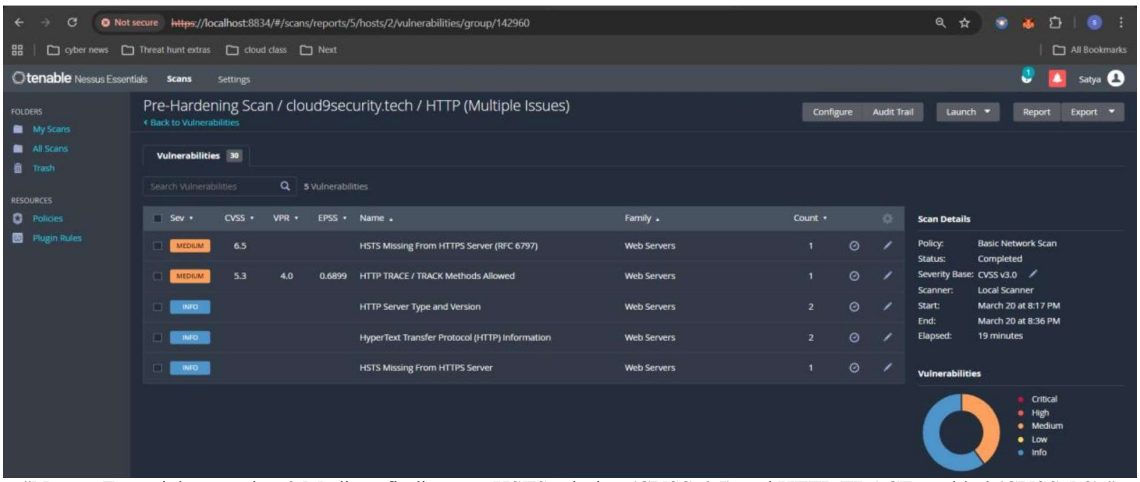
E4 - SSL Labs Grade A

SSL Labs returning Grade A pre-hardening — certificate valid but HSTS not yet implemented.



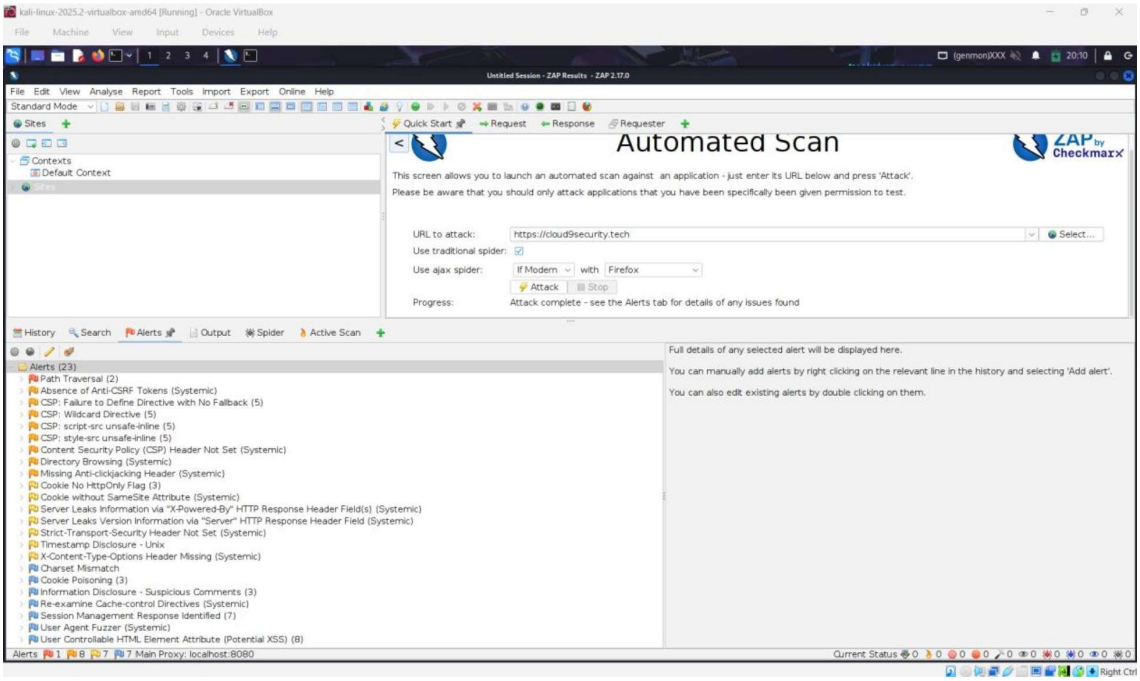


E5 - Nessus pre-hardening (2 Medium findings)



"Nessus Essentials returning 2 Medium findings — HSTS missing (CVSS 6.5) and HTTP TRACE enabled (CVSS 5.3)."

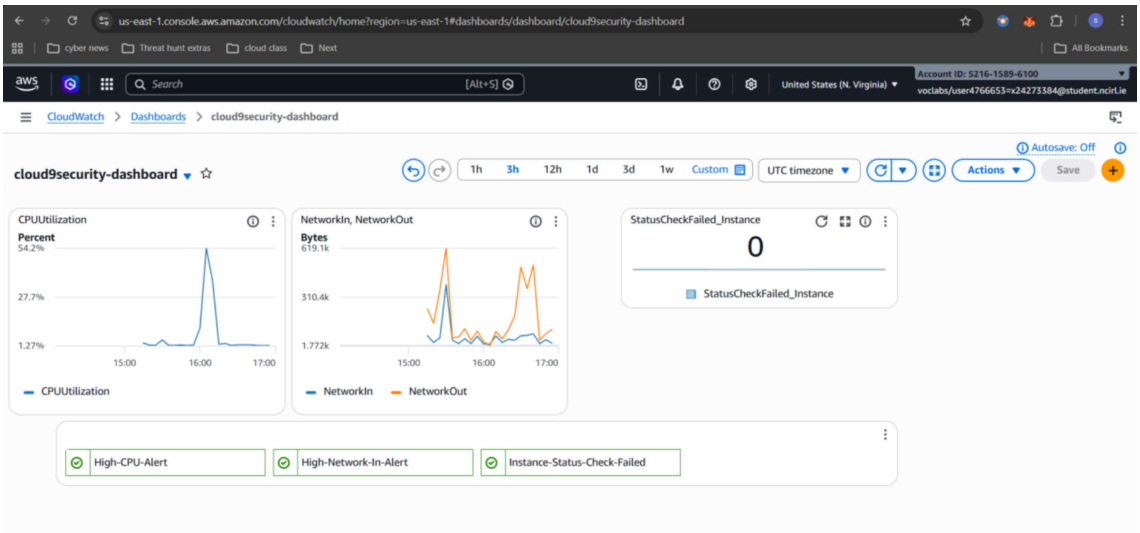
E6 - OWASP ZAP pre-hardening alerts (23 findings)



"OWASP ZAP returning 23 findings including path traversal, missing security headers, XSS instances and cookie vulnerabilities against cloud9security.tech."

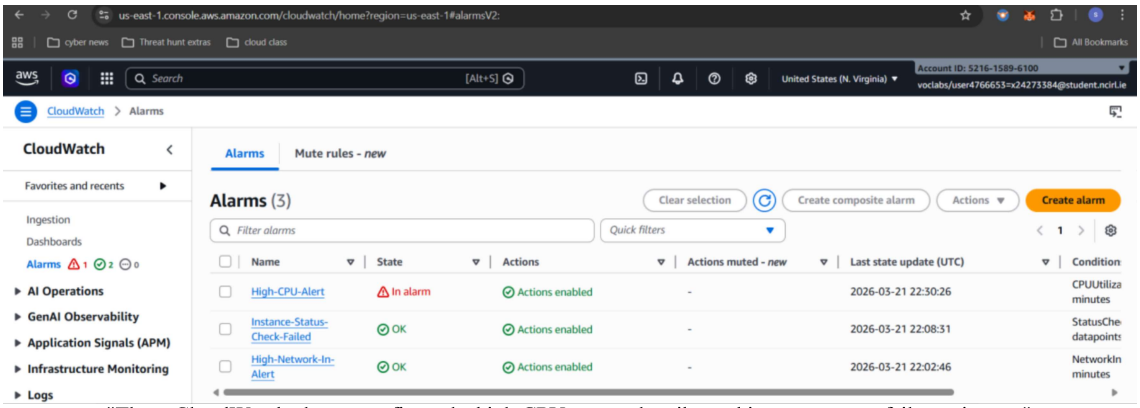
Appendix F - Monitoring and Alerting Evidence

F1 - CloudWatch Dashboard



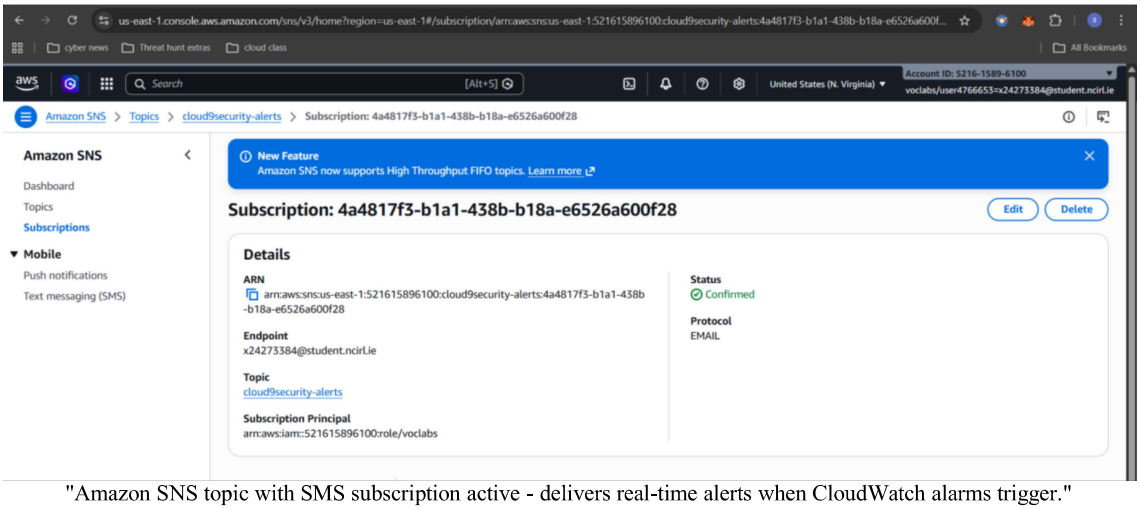
"AWS CloudWatch dashboard showing live EC2 metrics - CPU utilisation, network traffic and instance status checks."

F2 - CloudWatch Alarms



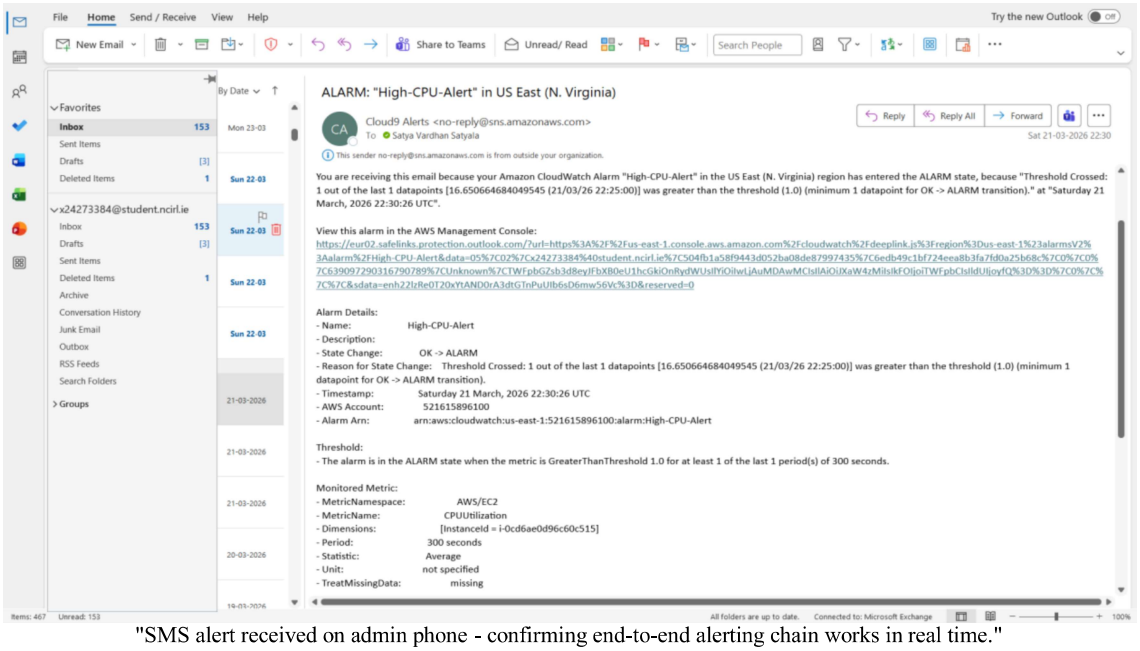
"Three CloudWatch alarms configured - high CPU, network spike and instance status failure triggers."

F3 - SNS Topic and Subscription



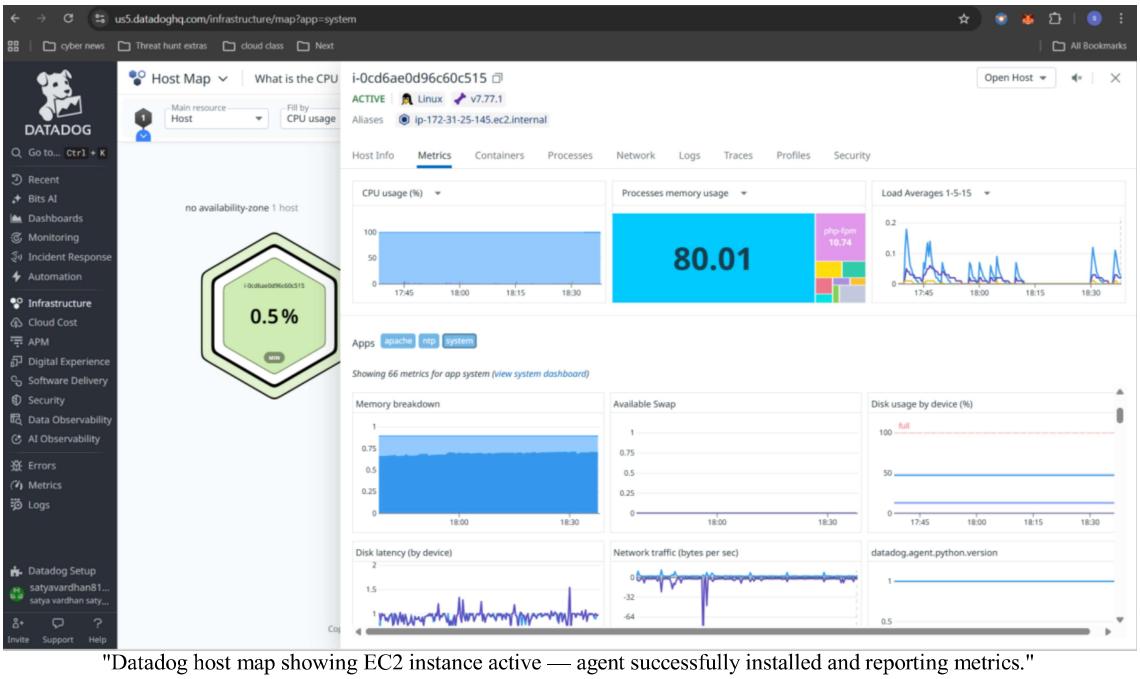
"Amazon SNS topic with SMS subscription active - delivers real-time alerts when CloudWatch alarms trigger."

F4 - SNS SMS Alert



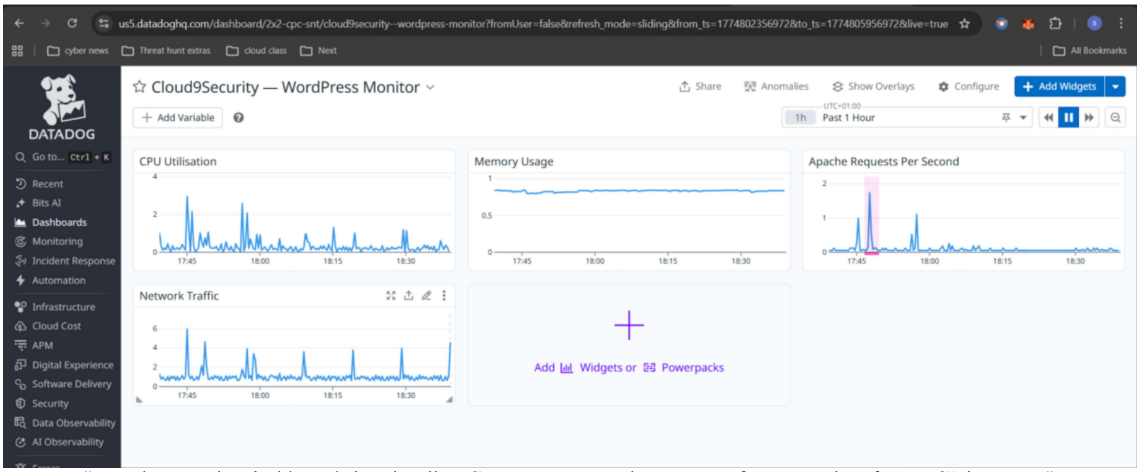
"SMS alert received on admin phone - confirming end-to-end alerting chain works in real time."

F5 - Datadog Host Map



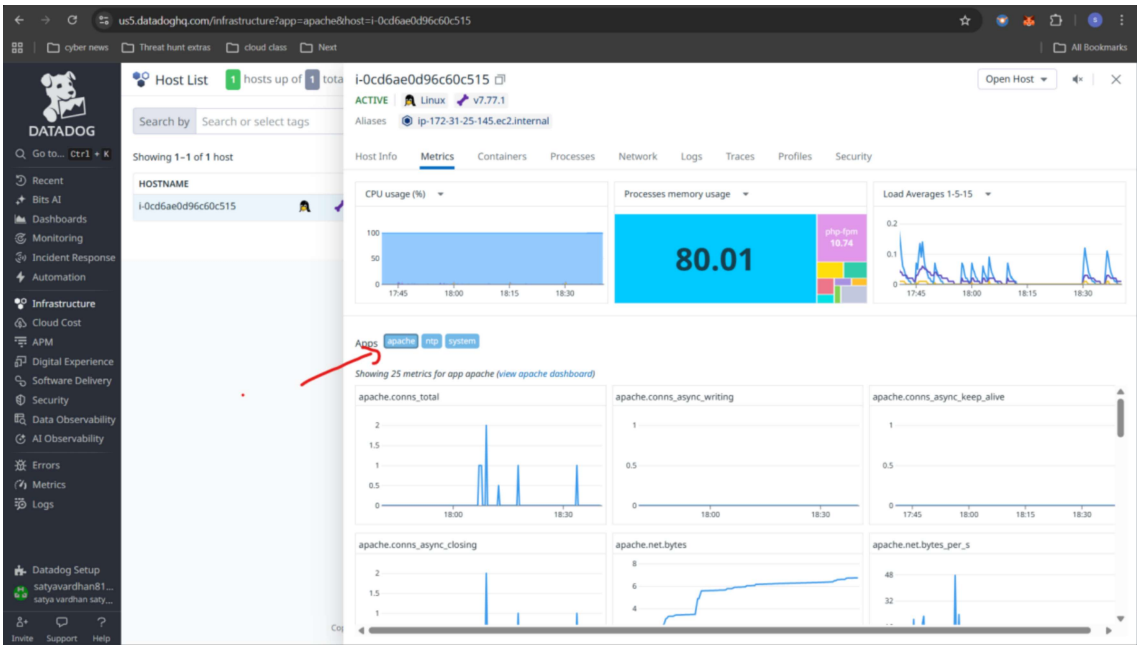
"Datadog host map showing EC2 instance active — agent successfully installed and reporting metrics."

F6 - Datadog Metrics Dashboard



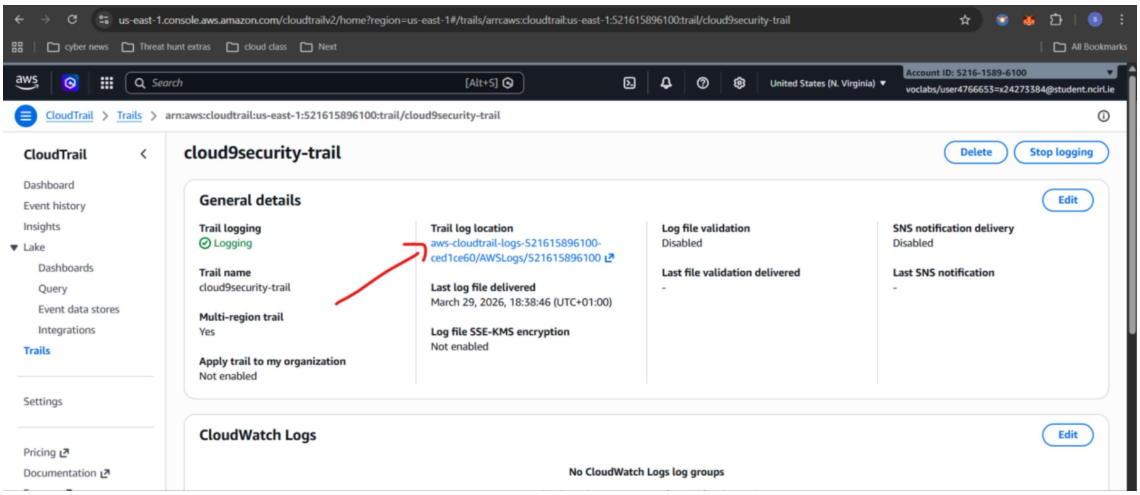
"Datadog metrics dashboard showing live CPU, memory and system performance data from EC2 instance."

F7 - Datadog Apache Integration



"Datadog Apache integration active — showing request rates and worker status from Apache mod_status endpoint."

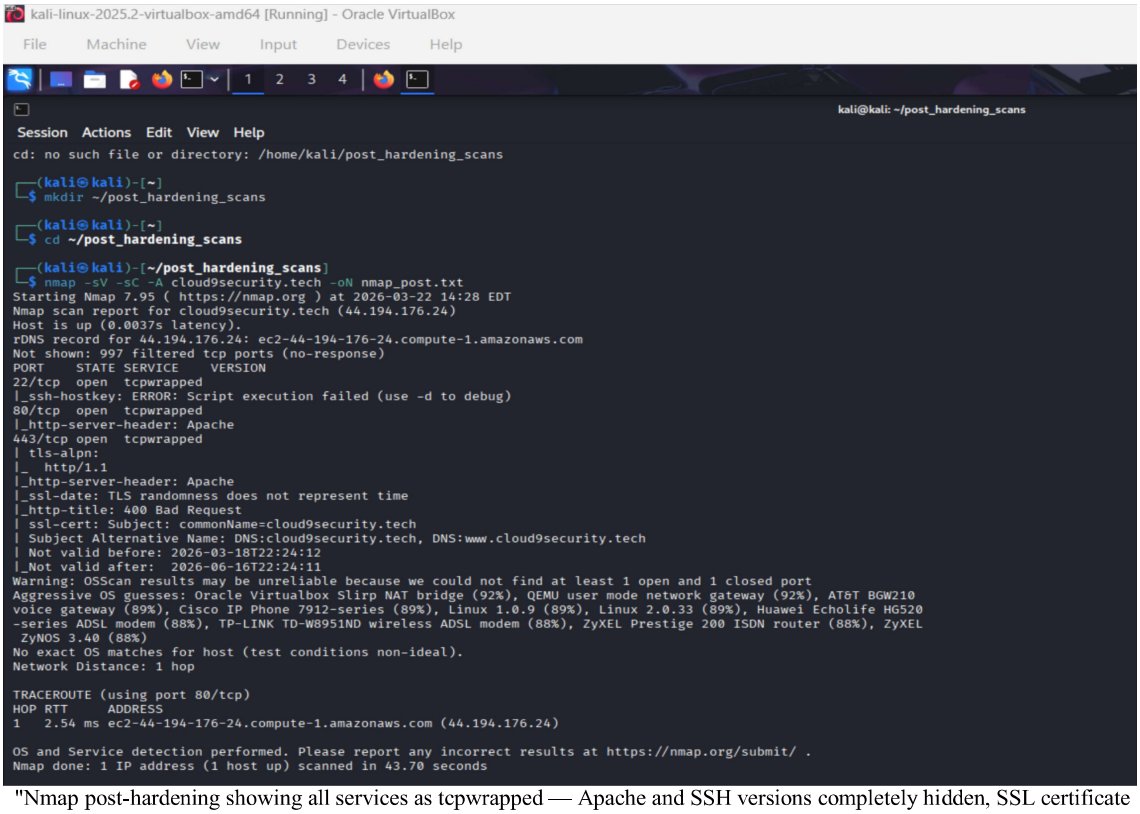
F8 - CloudTrail Trail Active



"AWS CloudTrail trail active and logging all API calls and console actions to S3 bucket."

Appendix G - Post-Hardening Scan Results

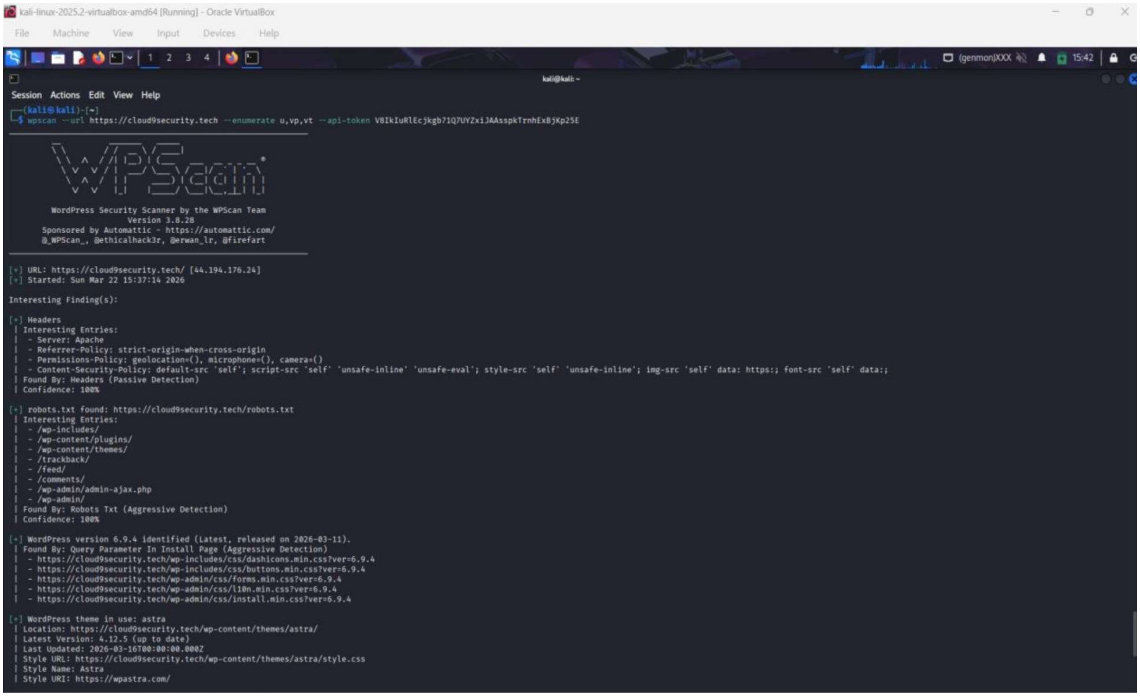
G1 - Nmap post (tcpwrapped, version hidden)



"Nmap post-hardening showing all services as tcpwrapped — Apache and SSH versions completely hidden, SSL certificate confirmed valid for cloud9security.tech."

G2 - WPScan post (No Users Found)

WPScan returning No Users Found — admin username no longer discoverable after RSS feeds and REST API endpoint blocked.





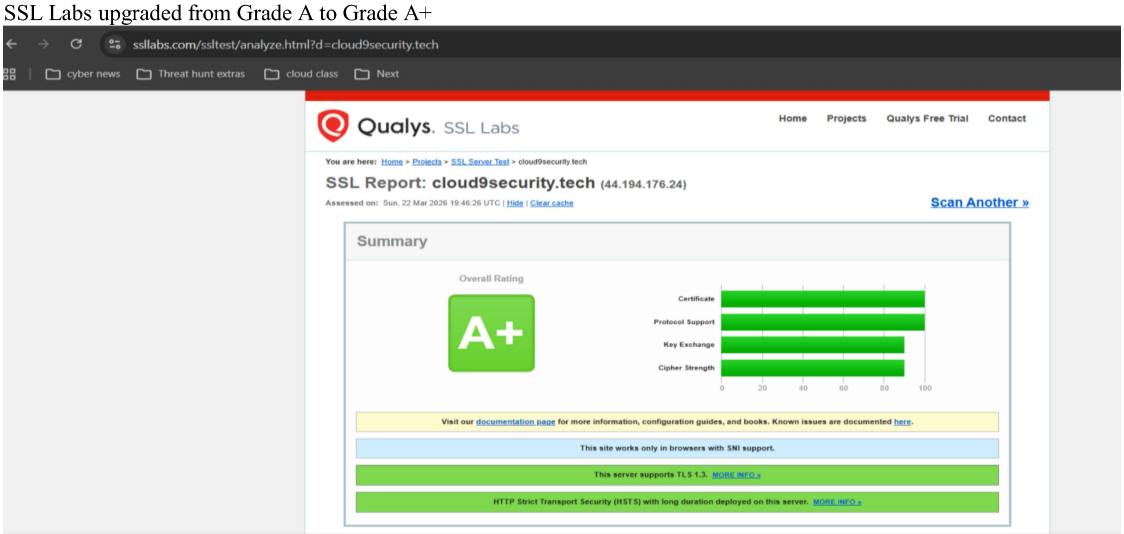
G3 - Nikto post



"Nikto returning 6 findings post-hardening compared to 19 pre-hardening — 68% reduction after security headers and file hardening."

G4 - SSL Labs Grade A+

SSL Labs upgraded from Grade A to Grade A+



Certificate #1: EC 256 bits (SHA384withECDSA)

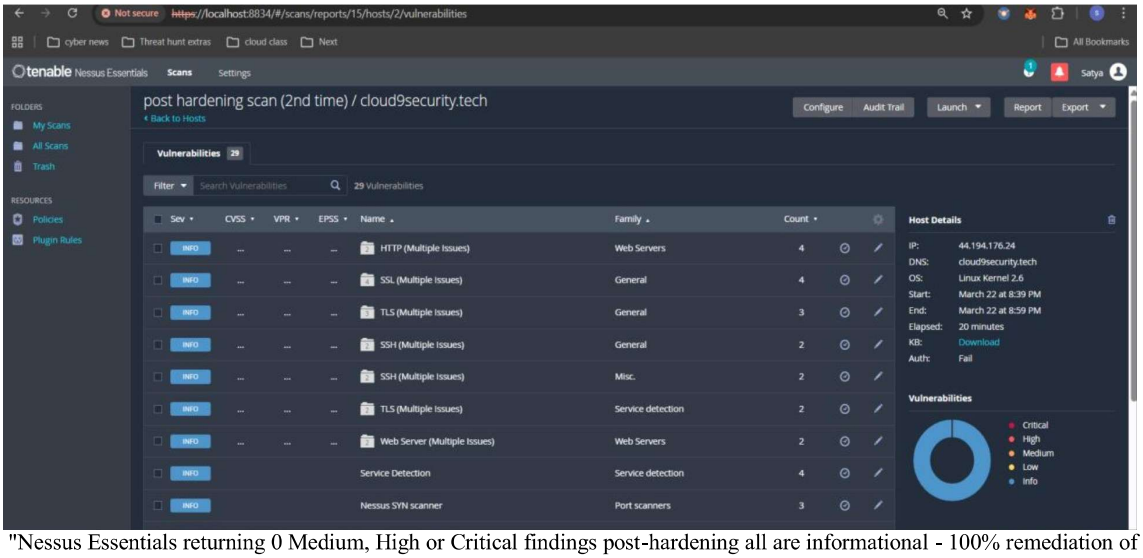
Server Key and Certificate #1

Subject	cloud9security.tech Fingerprint SHA256: f855d59b0a2155415e2828892e42f804c4aa1cc38d4afd085a7793350c6286d5 Pin SHA256: xy51QRU55BCBW67NFCc36aCp6KDUE2+zt326iepteOY=
Common names	cloud9security.tech
Alternative names	cloud9security.tech www.cloud9security.tech
Serial Number	05e4e1120d09d1f849d629f8059a572b1925
Valid from	Wed, 18 Mar 2026 22:24:12 UTC
Valid until	Tue, 16 Jun 2026 22:24:11 UTC (expires in 2 months and 25 days)
Key	EC 256 bits
Weak key (Debian)	No
Issuer	E7 AIA: http://e7.i.lencr.org/
Signature algorithm	SHA384withECDSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL CRL: http://e7.c.lencr.org/38.crl
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

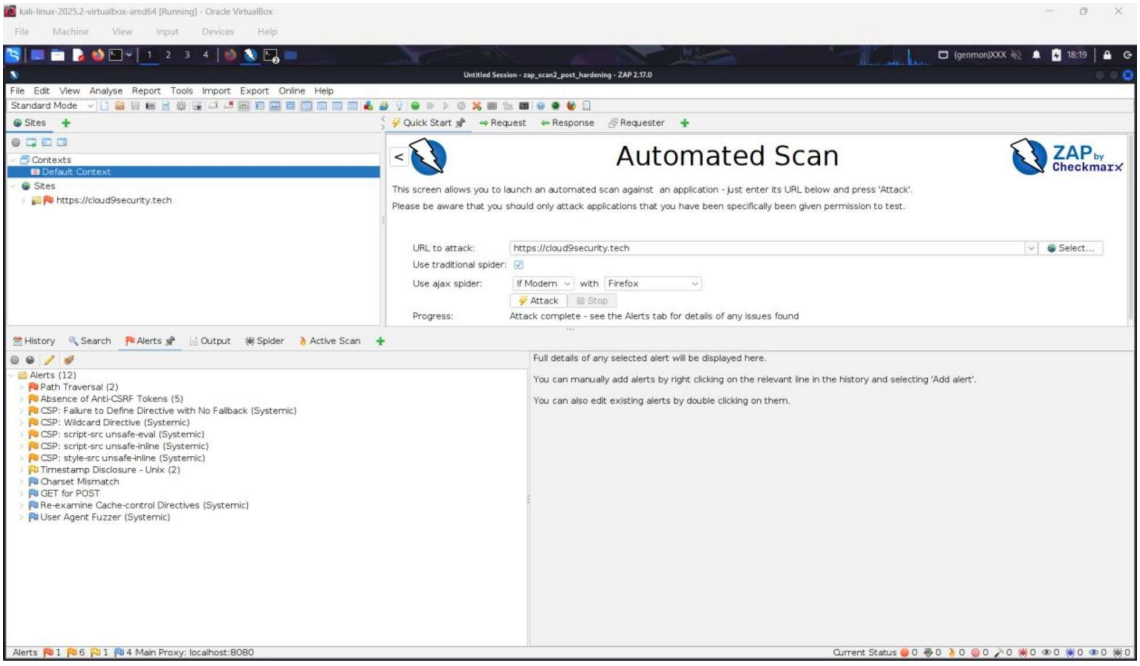
Certificates provided	2 (2057 bytes)
Chain issues	None
#2	
Subject	E7 Fingerprint SHA256: aeb1fd7410e83bc96f5da3c6a7c2c1bb836d1fa5cb86e708515890e428a8770b Pin SHA256: y7xVm0TVJNahMr2sZydE2jQH8SquXV9yLF9seROHHHU=
Valid until	Fri, 12 Mar 2027 23:59:59 UTC (expires in 11 months and 18 days)
Key	EC 384 bits
Issuer	ISRG Root X1
Signature algorithm	SHA256withRSA

G6 - Nessus post (0 Medium/High/Critical)



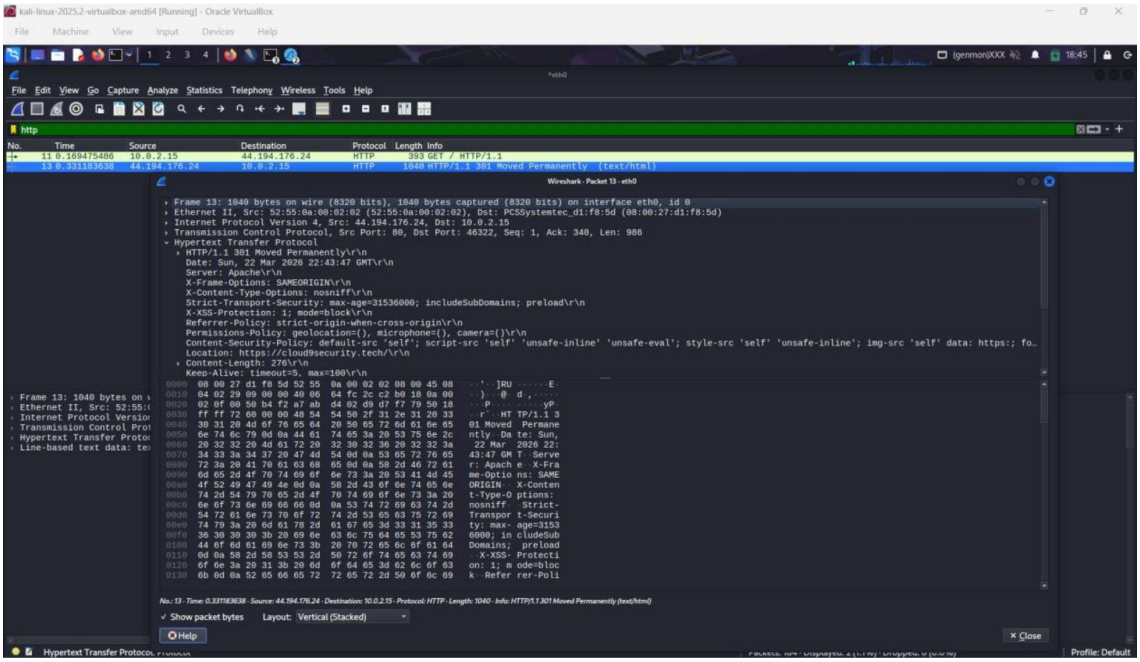
"Nessus Essentials returning 0 Medium, High or Critical findings post-hardening all are informational - 100% remediation of pre-hardening findings."

G7 - OWASP ZAP post



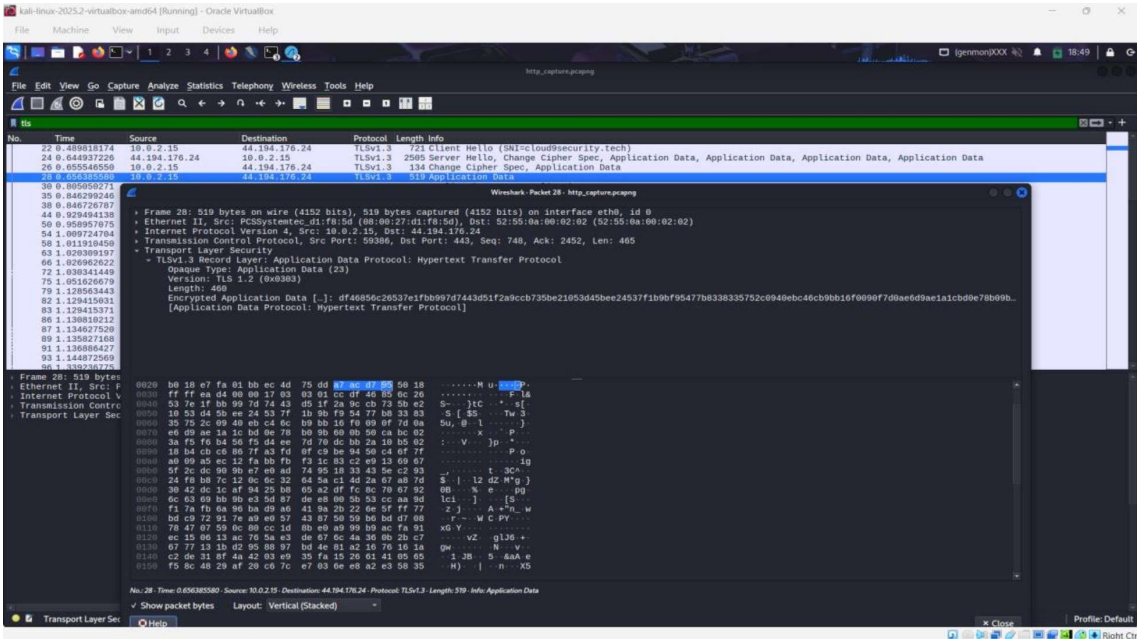
"OWASP ZAP returning 12 findings post-hardening compared to 23 pre-hardening."

G8 - Wireshark HTTP 301 redirect capture



"Wireshark capture confirming HTTP requests on port 80 return 301 Moved Permanently — all traffic automatically redirected to HTTPS, unencrypted content is never served."

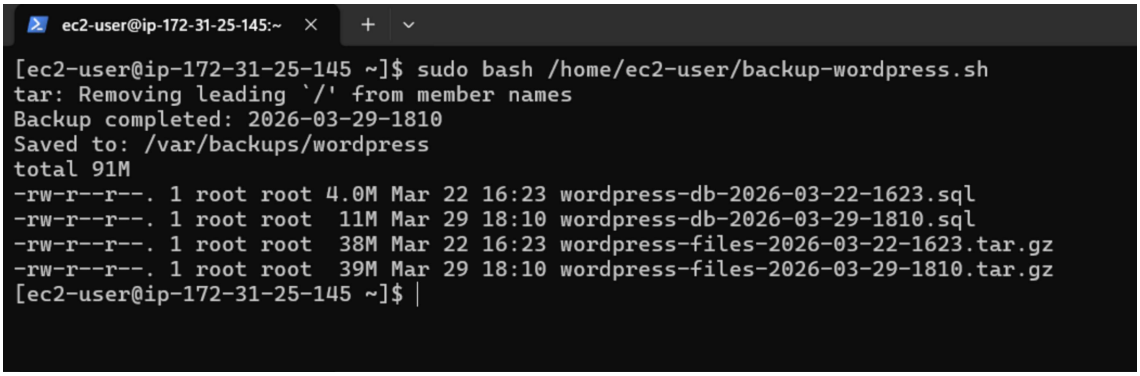
G9 - Wireshark TLS encrypted HTTPS capture



"Wireshark capture confirming all HTTPS traffic is encrypted using TLS 1.3 with AES-256-GCM"

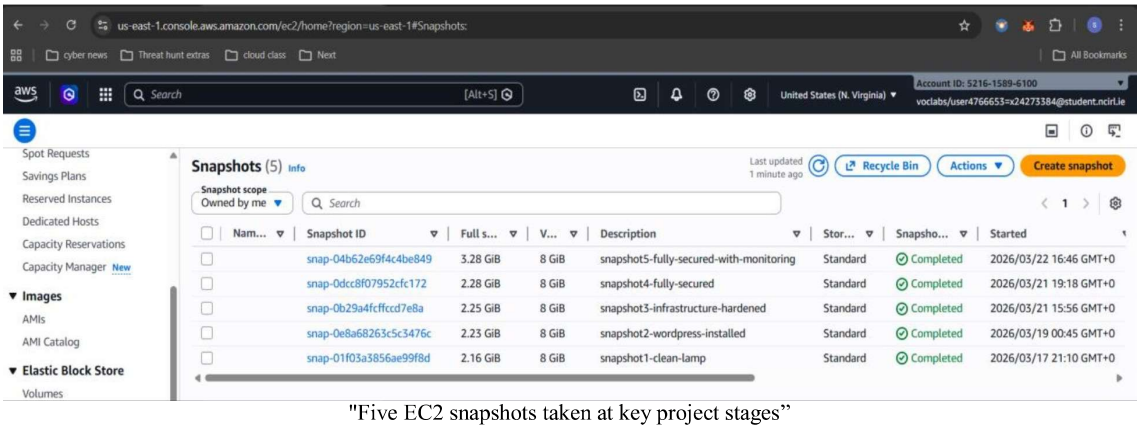
Appendix H - Backup and Recovery Evidence

H1 - Backup Script and Files



"WordPress backup script running successfully - database dump and files archive saved to /var/backups/wordpress, showing backups from two separate dates confirming automated daily execution."

H3 - EC2 Snapshots (5 stages)



"Five EC2 snapshots taken at key project stages"